Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА
Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Антропова Олега Романовича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Сканирование TCP-портов»

Состав выпускной квалификационной работы:
Расчетно-пояснительная записка на 119 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (Р.С. Лопатин)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ О.Р. Антропов
(подпись) (инициалы, фамилия)

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности

Кафедра Систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Антропову Олегу Романовичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Сканирование TCP-портов»

ФГБОУ ВО «ВГТУ», ВГТУ
по заданию какой организации выполняется работа

приказ №01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Исследование существующих баз данных и нормативных документов в области информационной безопасности
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Раздел 2. Установление взаимосвязей пар типа «шаблон атаки — уязвимость» для атак класса «Сканирование TCP-портов»

Раздел 3. Моделирование рисков и оценка вероятности успешной реализации кибератак

Раздел 4. Разработка организационно-правовых рекомендаций по снижению рисков для шаблонов класса «Сканирование TCP-портов»

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам)

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.25 – 22.05.25
2	Исследование существующих баз данных и нормативных документов в области информационной безопасности	22.03.25 – 22.05.25
3	Установление взаимосвязей пар типа «шаблон атаки — уязвимость» для атак класса «Сканирование TCP-портов»	23.05.25 – 31.05.25
4	Моделирование рисков и оценка вероятности успешной реализации кибератак	01.06.25 – 12.06.25
5	Разработка организационно-правовых рекомендаций по снижению рисков для шаблонов класса «Сканирование TCP-портов»	13.06.25 – 24.06.25
6	Заключение	25.06.25 – 02.07.25

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Антропова Олега Романовича

Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Сканирование TCP-портов»

Характеристика выпускной квалификационной работы

Актуальность исследования кибератаки класса «Сканирование TCP-портов» представляют серьезную угрозу для автоматизированной информационной сети, поскольку могут быть использованы для разведки в более вариативных сценариях вторжения. Однако нормативно-правовое поле в области информационной безопасности не располагает методиками для риска анализа атак класса «Сканирование TCP-портов». Существующие методики формирования организационно-правовых регламентов не учитывают специфики атаки.

Задачи, решаемые в ВКР:

– организация, сбора открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Сканирование TCP-портов» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Сканирование TCP-портов» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Сканирование TCP-портов» на уязвимости в автоматизированных информационных системах.

Структура ВКР

Введение – 6 страниц;

Глава 1. Исследование существующих баз данных и нормативных документов в области информационной безопасности;

Глава 2. Установление взаимосвязей пар типа «шаблон атаки – уязвимость» для атак класса «Сканирование TCP–портов» – 20 страниц;

Глава 3. Моделирование рисков и оценка вероятности успешной реализации кибератак – 30 страниц;

Глава 4. Разработка организационно-правовых рекомендаций по снижению рисков для атак класса «сканирование TCP-портов» – 4 страницы;

Заключение – 2 страницы;

Список литературы – 7 страниц;

Приложение А

Приложение В

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Исследование существующих баз данных и нормативных документов в области информационной безопасности.

Изучена структурированная база данных, содержащая сведения об атаках класса «Сканирование TCP-портов» и уязвимостях автоматизированных информационных систем (АИС).

Раздел 2. Установление взаимосвязей пар типа «шаблон атаки – уязвимость» для атак класса «Сканирование TCP–портов»

Построена модель взаимосвязей между атаками класса «Сканирование TCP-портов» и уязвимостями АИС, представленная в виде дерева графов, вершины которого соответствуют уязвимостям, а дуги отображают траектории атак, сопровождающиеся паспортизацией средств вторжения и сценариями атак.

Раздел 3. Моделирование рисков и оценка вероятности успешной реализации кибератак.

Выработаны методика для калькуляции рисков единичных атак класса «Сканирование TCP-портов», позволяющие учитывать вариативность атак и уязвимостей, обеспечивая точное прогнозирование риска.

Раздел 4. Разработка организационных мер по снижению рисков реализации выявленных сценариев атак

Сформированы организационно-правовые регламенты для снижения рисков, учитывающих как первичные меры реагирования, так и последующую ликвидацию последствий различных сценариев атак «Сканирование TCP портов»

Автор ВКР_____ Антропов Олег Романович.
(подпись)

СОДЕРЖАНИЕ

Введение 7

1 Исследование существующих баз данных и нормативных документов в области информационной безопасности 13

1.1 Исследование нормативных документов. и баз знаний в области защиты от кибератак 13

1.2 Изучение характеристик риск-калькуляторов 18

2 Установление взаимосвязей пар типа «шаблон атаки — уязвимость» для атак класса «Сканирование TCP-портов» 24

2.1 Систематизация соответствий между CAPEC-шаблонами атак и эксплуатируемыми ими уязвимостями 24

2.2 Сопоставление полученных взаимосвязей с матрицей MITRE ATT&CK 37

3 Моделирование рисков и оценка вероятности успешной реализации кибератак .. 43

3.1 Определение критичности эксплуатируемых уязвимостей 43

3.2 Расчет рисков успешной реализации сформированных сценариев атак 56

4 Разработка организационно-правовых рекомендаций по снижению рисков для атак класса «Сканирование TCP-портов» 74

4.1 Разработка организационных мер по снижению рисков реализации выявленных сценариев атак 74

Заключение 77

Список литературы ..... **Ошибка! Закладка не определена.**

Приложение А 87

Приложение Б 111

ВВЕДЕНИЕ

Обеспечение информационной безопасности автоматизированной информационной системы сегодня – работа с целым кластером взаимосвязанных вопросов, требующих рассмотрения в рамках усиления уровня защищенности [1-8]. Так, с октября 2024 число инцидентов в информационной безопасности выросло на 13%, в сравнении с аналогичным периодом в 2023 году. Детально проанализировав статистику о возникающих инцидентах, можно увидеть, что: вредоносное ПО остается одним из наиболее популярных инструментов злоумышленников. Оно применяется в 66% успешных атак на организации и 51% атак на частные лица. При этом следует отметить, что атаки с использованием социальной инженерии остаются одними из самых популярных направлений. Доля шпионского ПО в атаках на организации выросла на 20%. В 48% случаев атакующие были нацелены на финансовую выгоду [9].

Кроме того, больше половины реализованных инцидентов в отношении автоматизированных информационных сетей приводила к раскрытию конфиденциальной информации, а треть случаев приводила к нарушению доступности.

Исследование статистики Ростелеком, проведённое в 2024 году, выявляет неудовлетворительное состояние защищённости автоматизированных информационных систем: в 91% случаев фиксируется наличие уязвимости, эксплуатация которой с высокой вероятностью приводит к успешной реализации атаки. Анализ данных свидетельствует о возросшей тщательности в действиях злоумышленников, которые всё чаще прибегают к активному сетевому сканированию для обнаружения наиболее уязвимых компонентов системы [12].

Только 40% компаний могут похвастаться наличием специализированных отделов по вопросам информационной безопасности. В то же время, в половине организаций функции защиты лежат на IT-отделах компаниях [11].

Вышеизложенное свидетельствует, что арсенал противодействия сетевым атакам все еще не совершенен, в том числе в части исследований по противодействию различным атакам [32-57].

Перечисленные ниже исследования ориентированы на обеспечение безопасности организации [32-38], автоматизированных систем и иных сервисов [39, 40], а также защита сетевое киберпространство [51,52] в отношении противодействия разнообразным кибератакам [50-53] и уязвимостям [43-46], в том числе с использованием средств искусственного интеллекта [37,49]. Однако, общим предметом исследования в них выступают оценка и регулирование информационных рисков, чему, собственно, и посвящена настоящая работа.

TCP-протокол (Transmission Control Protocol) лежит в основе подавляющего большинства сетевых взаимодействий в современных информационных системах.

На основе уникального набора данных о трафике по всему Интернету за последние 10 лет, представленного в исследовании «Have you SYN me»,, нам удалось выявить, что за десять лет интенсивность активной сетевой разведки выросла примерно в 30 раз (750 млн сканирующих кампаний, отправивших более 45 млрд пакетов).[10].

Эти сведения указывают на увеличение частоты применения данного метода атак киберпреступниками. Сканирование TCP-портов играет ключевую роль в рамках любой сетевой атаки. Через TCP взаимодействуют жизненно важные сервисы, такие как веб-серверы, хранилища данных, средства удаленного доступа т.д. По этой причине атаки, осуществляемые с применением разведки портов, имеющих отношение к TCP, представляют серьезную опасность. Основной задачей злоумышленника выступает скрытое получение информации о состоянии портов, запущенных службах и данных о системе.

Вот переработанный вариант с добавлением упоминания о базах данных:

Существующие методики для минимизации рисков, связанных с атаками класса «Сканирование TCP-портов», показывают, что несмотря на многообразие подходов — от пороговых алгоритмов TRWS и TAPS для обнаружения сканирования до механизмов анализа аномального трафика в IDS и современных NIGS с функцией машинного обучения, а также использование специализированных баз данных [13-21] и риск-калькуляторов [22-30], проблема остаётся актуальной. Атаки из класса «Сканирование TCP-портов» даже в нынешних условиях способны успешно обходить многие решения.

Проведенное исследование аналогов [58-63] позволяет предложить следующее целеполагание настоящего исследования.

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Сканирование TCP-портов».

Предметом исследования является процесс обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Сканирование TCP-портов», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышении защищенности автоматизированных информационных систем от атак класса «Сканирование TCP-портов» Исследование аналогов показало наличие ряда **противоречий** между:

– необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака – уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Сканирование TCP-портов»;

– потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

– существующей методологией вероятностной оценки опасности кибератак класса «Сканирование TCP-портов» использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

– несовершенством процедур регламентации противодействия кибератакам класса «Сканирование TCP-портов» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения выявленных противоречий и достижения поставленной цели необходимо решить **следующие задачи**:

– организация, сбора открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Сканирование TCP-портов» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Сканирование TCP-портов» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Сканирование TCP-портов» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

– структурирована база данных кибератак класса «Сканирование TCP-портов» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Сканирование TCP-портов», с учётом специфики используемых злоумышленников сценариев;

– комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Сканирование TCP-портов» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

− в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализа-

ции класса кибератак «Сканирование TCP-портов», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

− впервые для класса кибератак «Сканирование TCP-портов» была предложены обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

− в отличие от аналогов, предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Сканирование TCP-портов», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

− для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Сканирование TCP портов».

Практическая ценность полученных результатов состоит в том, что:

− созданная база данных метрик кибератак класса «Сканирование TCP- портов» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

− сформированное множество сценариев и их риск-анализ отражает практику реализации проектной деятельности защиты АИС от атак «Сканирование TCP-портов»;

− предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Сканирование TCP-портов», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

– предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Сканирование TCP-портов» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

− сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

– разработанные сценарии атак класса «Сканирование TCP-портов» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

– представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Сканирование TCP-портов», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

– в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Сканирование TCP-портов» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Исследование нормативных документов и существующих баз данных в области информационной безопасности

1.1 Анализ содержания нормативных документов и баз данных в области кибератак

Сегодня автоматизированные информационные системы – это то, без чего не может существовать ни одно предприятие. Защита таких механизмов требует постоянного улучшения подходов и методик. Одно из основных аспектов работы подобных систем – использование стандартов и нормативных документов, которые будут регулировать требования к безопасности информационных технологий. Само собой, основное внимание уделяется государственным стандартам (ГОСТ).

Существующие стандарты безопасности больше фокусируются на общих принципах защиты, чем на специфических уязвимостях, связанных с сетевой разведкой. Такой подход не гарантирует выявления всех потенциальных проблем. Из-за этого, при разработке систем безопасности, уязвимости, связанные именно с сетевой разведкой данных, могут быть пропущены, оставаясь незамеченными. В результате, система может считаться безопасной согласно стандартам, но на практике оставаться уязвимой для атак, направленных на сетевую разведку. Проще говоря, общие принципы — это хороший фундамент, но недостаточный для обеспечения полной защиты от всех возможных угроз, особенно специфичных для сканирования портов. Необходимо дополнять общие принципы более детальным анализом и учётом конкретных уязвимостей, свойственных методам сканирования портов.

С целью повышения уровня защищенности автоматизированных систем сканирования портов от атак типа "Сканирование TCP-портов", был проведен анализ возможности применения ряда существующих государственных стандартов, регулирующих информационную безопасность [58-63].

ГОСТ Р ИСО/МЭК 15408-2-2013, являющийся частью международной системы общих критериев (Common Criteria), посвящён вопросам оценки защищённости информационных систем [58]. Этот стандарт описывает методы оценки функциональных элементов безопасности, однако не рассматривает все возможные сценарии атак.

Он сосредотачивается на предоставлении рамок для анализа и оценки конкретных аспектов безопасности, но не является исчерпывающим руководством по предотвращению всех потенциальных угроз.

Данный стандарт рассматривает очень большой спектр мер (мониторинг, контроль доступа, идентификация, криптография, реагирование на инциденты). Анализ выбранных нами атак показывает, что данный стандарт может быть недостаточно надежным.

ГОСТ Р ИСО/МЭК 27001-2021 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования», ориентирован на установление, внедрение и поддержание СУИБ, обеспечивая уверенность в управление рисками [59].

Стандарт предлагает общие процедуры реагирования на всевозможные инциденты, но не предоставляет никаких конкретных шагов, которые бы помогли определить, отреагировать и восстановиться после атаки. Кроме того, стандарт не детализирует методы анализа, понимания и устранения конкретных уязвимостей в сканирование портов, которые открывают путь для атак.

ГОСТ Р 59710-2022 «Защита информации. Управление компьютерными инцидентами. Общие положения» [60], уделяющий внимание регулированию компьютерными инцидентами, представляет собой стандарт, нацеленный на общую систему управления кибербезопасностью.

Стандарт не включает в себя четких указаний по защите от атак, использующих недостатки механизмов защиты портов. Кроме того, стандарт делает основной упор на меры реагирования на уже произошедшие инциденты, а не на заблаговременное предотвращение угроз. Несмотря на важность реагирования, профилактические меры, направленные на исключение уязвимостей в обработке данных (такие как проверка входных данных), являются критически важными.

Также стандарт не предлагает определенных методик для выявления уязвимостей в процессах сканирования портов или разработки специализированных систем мониторинга данных, подверженных риску атак.

ГОСТ Р 59711-2022 «Защита информации. Управление компьютерными инцидентами. Организация деятельности по управлению компьютерными инцидентами» [61]. Данный стандарт описывает организацию и процессы, которые необходимы для эффективного реагирования на инциденты. Главный фокус данного ГОСТа – фокусировка на реагировании, а не на профилактике.

Стандарт ГОСТ Р 59547-2021, озаглавленный «Защита информации. Мониторинг информационной безопасности. Общие положения», регламентирует процедуры наблюдения и управления рисками, необходимые для поддержания информационной безопасности [62], охватывая такие аспекты, как секретность, сохранность и готовность данных. Вместе с тем, анализ документа выявляет, что акцент непосредственно на атаку типа "Сканирование TCP-портов" выражен недостаточно. Среди минусов – упор на обнаружении, отсутствие конкретных методик анализа и недостаточная детализация мониторинга данных.

ИСО/МЭК 13335-1:2006. Информационная технология - Методы обеспечения безопасности - Управление безопасностью информационных и телекоммуникационных технологий - Часть 1 - Концепция и модели управления безопасностью информационных и телекоммуникационных технологий [63].

В стандарте не указано, каким образом конкретно отслеживать и анализировать события, касающиеся сканирования портов, для обнаружения подозрительной активности. Кроме того, управление доступом, описанное в стандарте, не гарантирует конкретных действий по защите от злоупотреблений механизмами сканирования портов.

Изученные нормы регламентируют основные подходы к построению системы защиты информации и борьбы с угрозами. Но в части атак типа «Сканирование TCP-портов» они оказываются неполными. Нормативные документы в основном затрагивают выявление и разрешение инцидентов, не уделяя должного внимания созданию превентивных мер.

Этот пробел в нормах указывает на важность привлечения дополнительных ресурсов, таких как постоянно обновляемые базы данных, которые мониторят новые виды атак и предлагают современные методы противодействия им.

CAPEC (Common Attack Pattern Enumeration and Classification), каталог известных шаблонов атак в кибербезопасности. Созданный в 2007 году Министерством внутренней безопасности США (как инициатива Управления кибербезопасности и коммуникаций), CAPEC сейчас поддерживается и управляется некоммерческой организацией MITRE, которая также заведует рядом исследовательских центров, спонсируемых федеральным правительством.

CAPEC – это не только список уязвимостей, но и исчерпывающий словарь и классификатор известных моделей атак. Он представляет собой организованный обзор злонамеренных действий, охватывающий полный цикл атаки – от сбора информации до ее реализации. В отличие от обычных каталогов уязвимостей, ориентированных на технические детали, CAPEC описывает стратегии атак, включая их задачи, методы и потенциальные меры защиты [13]. Каждая запись включает сведения об уровне сложности проведения атаки, что позволяет более точно оценивать потенциальный риск. Этот общепринятый стандарт терминологии для описания кибератак используется экспертами в области кибербезопасности для минимизации рисков и улучшения общего понимания угроз.

Не трудно догадаться, что и у такой системы есть свои недостатки и противоречия. Приведем два основных (те, что ограничивают его эффективность):

Для результативного использования требуется полная и достаточная информация о шаблонах. При всем этом отсутствует полноценный перевод материалов на русский язык, что усложняет применение для тех, кто английским языком не владеет.

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) – это общедоступный сборник знаний о стратегиях и методах, используемых злоумышленниками, основанный на реальных примерах. ATT&CK, разработанный MITRE в 2013 году, опирается на опыт экспертов в области кибербезопасности для документирования конкретных техник, тактик и процедур (TTP), применяемых киберпреступниками в своих атаках.

ATT&CK служит базой для создания моделей угроз и методологий, используемых коммерческими компаниями, государственными организациями, а также сооб-

ществом разработчиков продуктов и услуг в области кибербезопасности. Она позволяет аналитикам и специалистам по безопасности не только классифицировать атаки, но и получать более глубокое понимание того, как злоумышленники взаимодействуют с системами, их подходы на каждом этапе атаки и способы защиты от этих действий.

Основываясь на реальных данных об инцидентах кибербезопасности, MITRE ATT&CK стала отраслевым стандартом для знаний и инструментов предотвращения киберугроз. Её структура организована в разделы, отражающие тактические и технические действия, характерные для атаки. С помощью MITRE ATT&CK специалисты могут не только анализировать происшедшие атаки, но и создавать действенные стратегии для предотвращения потенциальных угроз. ATT&CK – это открытый ресурс, доступный для бесплатного использования любым лицом или организацией.

MITRE ATT&CK предоставляет уникальную возможность детального изучения действий злоумышленников, позволяя специалистам по безопасности повышать эффективность защиты на всех этапах кибератаки.

Конечно же упомянем и о недостатках: неполнота сведений, осложнение анализа из-за обширного объема информации и неспособность отражать реальную последовательность действий злоумышленников.

NVD (National Vulnerability Database) – государственное хранилище США, управляемое Национальным институтом стандартов и технологий (NIST). NVD представляет собой централизованное хранилище данных, которое содержит унифицированную информацию об управлении уязвимостями. Данные представлены в формате, поддерживаемом протоколом SCAP, что обеспечивает автоматизацию процессов, связанных с управлением уязвимостями, оценкой уровня безопасности и соответствием нормативным требованиям [19].

Из минусов – фиксация только официально зарегистрированных уязвимостей, ограничения в оценке критичности уязвимостей и отсутствие покрытия для вредоносных пакетов.

Банк данных угроз безопасности информации Федеральной службы технико-экспортного контроля России (БДУ ФСТЭК России) сосредотачивает внимание на

систематизации угроз, уязвимостей и методов защиты, соответствующих российским стандартам, нормативным предписаниям и законодательству в сфере информационной безопасности. Таким образом, база данных предоставляет сведения, адаптированные под российский контекст и специфику.

Эта база данных охватывает широкий круг вопросов, связанных с информационной безопасностью, в том числе слабые места в операционных системах, приложениях, сетевом оборудовании, а также риски, возникающие из-за кибератак и других нарушений. Она содержит сведения об уязвимостях программного обеспечения, которые классифицируются по уровню опасности и потенциальному ущербу [13].

Значимым преимуществом БДУ ФСТЭК России является её взаимодействие с другими российскими и зарубежными источниками данных о безопасности. Это способствует созданию более всестороннего и точного представления об актуальных угрозах и уязвимостях, давая возможность определять связи и тенденции в киберсреде. Кроме того, база данных предлагает практические советы по устранению слабых мест и предотвращению инцидентов, что позволяет специалистам по безопасности быстро реагировать на появляющиеся риски и эффективно защищать информационные системы.

Минусы – сложность из-за канцеляризмов, несоответствие актуальным методикам моделирования угроз, обращение внимания лишь на трех типах последствий (нарушение конфиденциальности, доступность и целостность). Кроме того, по сравнению с крупными международными реестрами, такими как CVE, БДУ ФСТЭК России содержит значительно меньше данных об уязвимостях, что ограничивает полноту анализа и возможности оперативного реагирования на новые угрозы.

1.2 Изучение характеристик риск-калькуляторов

Ключевым аспектом результативного контроля рисков в сфере информационной безопасности выступает безошибочное установление степени угрозы выявленных слабых мест. В нынешних условиях предприятия ежедневно сталкиваются с ко-

лоссальным числом уязвимостей, и отсутствие отлаженной системы оценивания делает невозможным расстановку приоритетов в процессе нейтрализации опасных факторов. Расскажем о системах оценки уязвимости, которые применяются в данных случаях.

Система CVSS (Common Vulnerability Scoring System) представляет собой стандартизированный подход к оценке уязвимостей, разработанный для численной характеристики степени их опасности для информационной безопасности. Целью CVSS является определение потенциального ущерба, который может нанести эксплуатация конкретной уязвимости. Оценка производится на основе специализированных алгоритмов, учитывающих ряд ключевых параметров, и позволяет получить приблизительное представление о сложности использования уязвимости и масштабах ее возможных последствий для системы.

В соответствии с системой CVSS, оценка уязвимостей производится на базе ряда параметров, которые классифицируются на три главных категории:

Основные метрики: Данные параметры характеризуют уязвимость как таковую, оставаясь неизменными вне зависимости от времени или конкретной инфраструктуры. Они подразделяются на две подгруппы:

Метрики эксплуатации: оценивают простоту использования уязвимости. К примеру, одни уязвимости могут быть использованы удаленно через интернет, в то время как другие требуют непосредственного физического доступа, что усложняет их использование неквалифицированным злоумышленником. Дополнительно учитывается сложность осуществления атаки, необходимость взаимодействия с пользователем и требуемый уровень прав доступа для проведения атаки.

Метрики воздействия: оценивают последствия успешной эксплуатации, включая вероятность нарушения работоспособности системы, получения доступа к конфиденциальным данным и внесения изменений в информацию.

Временные метрики: описывают внешние факторы, которые подвержены изменениям с течением времени, например, существование эксплойтов в открытом доступе или выпуск патчей безопасности.

Метрики окружения: Эти параметры не оказывают влияния на базовую оценку уязвимости, но позволяют определить уровень риска для конкретной информационной среды. Они включают в себя базовые метрики, адаптированные к специфическим условиям. Например, если для эксплуатации в общих условиях требуются минимальные права, то в организации доступ к уязвимой системе может быть предоставлен только администраторам. Кроме того, данные метрики описывают потенциальные последствия эксплуатации для бизнеса, такие как влияние простоя сервера на бизнес-процессы компании и наличие резервных механизмов.

Оценивание происходит поэтапно: сначала определяется основная оценка, которая затем уточняется с учетом временных и контекстуальных факторов. Поставщики информации предоставляют первичные и временные показатели, в то время как эксперты или владельцы систем должны самостоятельно корректировать оценки, учитывая особенности окружения. Для временных показателей по умолчанию используются значения, соответствующие наиболее негативному развитию событий (например, наличие общедоступного эксплойта).

Базовые показатели отражают "внутренние" аспекты уязвимости, которые не меняются и не зависят от особенностей конкретной организации.

Метрики, учитывающие контекст, позволяют принимать во внимание особенности окружения, в котором функционирует определенная система. В рамках этого контекста могут применяться механизмы защиты или установленные правила, которые снижают или полностью устраняют возможную угрозу. К контекстным метрикам относятся:

Параметры конфиденциальности, целостности и доступности – эти характеристики дают возможность корректировать оценку уязвимости, опираясь на значимость IT-актива для деятельности компании. Например, для системы управления электронной очередью может быть критичной высокая целостность и доступность, при этом требования к конфиденциальности могут быть менее строгими.

Скорректированные базовые метрики – эта категория включает те же параметры, что и базовые метрики (Base), но позволяет пользователю пересмотреть отдельные показатели, исходя из специфики конкретной среды. К примеру, присутствие

определенных средств защиты или регламентов может повлиять на сложность реализации атаки. Если модифицированная базовая метрика не определена, в расчете будет использовано исходное значение базовой метрики. В противном случае, указанное значение заменит базовую метрику.

CVSS 4.0 отличается гибкой структурой, учитывающей сложность атак с точки зрения возможностей злоумышленника, и детально анализирует аспекты влияния на конфиденциальность, целостность и доступность информации. Это способствует повышению эффективности управления рисками, приоретизацией угроз и реагированию на инциденты [26].

CVSS 4.0 содержит три группы метрик: базовые, временные и экологические.

Базовые метрики оценивают серьезность уязвимости без учета конкретных условий и контекста. Временные метрики учитывают изменения серьезности уязвимости со временем, в зависимости от доступности сведений и инструментов. Экологические метрики отражают влияние уязвимости с учетом специфических условий и особенностей среды, в которой она обнаружена.

Итоговый балл CVSS, вычисляемый на основе значений метрик, находится в диапазоне от 0 до 10. При этом 0 указывает на отсутствие значительной опасности, а 10 свидетельствует о наивысшей степени критичности уязвимости.

Адаптируемая архитектура CVSS 4.0 позволяет компаниям настраивать систему в соответствии со своими потребностями. Они могут добавлять новые или модифицировать существующие метрики, чтобы более точно отражать специфические риски и приоритеты своей организации.

Главная цель EPSS – спрогнозировать вероятность использования уязвимости в течение месяца, предоставляя числовую оценку в диапазоне от 0 до 1, где 1 указывает на максимальный риск. Для достижения этой цели система учитывает множество факторов, включая категорию уязвимости, наличие информации об эксплойтах в публичных ресурсах, активность злоумышленников, сведения о выпущенных обновлениях, а также популярность и поставщика программного обеспечения [27].

EPSS оценивает эффективность процесса защиты двумя основными метриками:

− эффективность − отношение количества устранённых эксплуатируемых уязвимостей (True Positives, TP) к сумме TP и ложных срабатываний (False Positives, FP);

− охват − отношение TP к сумме TP и пропущенных уязвимостей (False Negatives, FN).

Несмотря на все преимущества, система имеет и ряд ограничений. Прежде всего, эффективность модели ограничена качеством и объемом входящей информации, что особенно сказывается на определении вероятности эксплуатации для малоизученных или недавно обнаруженных уязвимостей.

Во-вторых, система EPSS не принимает во внимание уникальные характеристики каждой отдельной компании, что может снижать релевантность ее оценок в определенных ситуациях.

В-третьих, EPSS фокусируется исключительно на вероятности успешной эксплуатации, не принимая во внимание возможный ущерб от этого, поэтому для комплексного анализа рисков рекомендуется применять ее совместно с другими методологиями, такими как CVSS. К тому же, интеграция EPSS с распространенными средствами защиты информации на данный момент имеет некоторые ограничения.

Современная цифровая сфера динамично меняется, что повышает требования к защищенности веб-приложений. В этой связи, важным инструментом для оценки и контроля рисков, связанных с уязвимостями, стал калькулятор рисков, разработанный OWASP [28].

Этот инструмент учитывает как аспекты технического характера, так и факторы, влияющие на бизнес, разделяя оценку рисков на две ключевые составляющие: вероятность эксплуатации уязвимости и потенциальный ущерб. Каждая из этих составляющих детализируется на отдельные метрики, оцениваемые по шкале от низкого до высокого уровня риска. На основе этих оценок, калькулятор формирует общую оценку риска, позволяя классифицировать уязвимости по уровням: низкий, средний и высокий. Такой подход позволяет специалистам принимать обоснованные решения относительно того, каким проблемам следует уделить первоочередное внимание.

Калькулятор OWASP Risk Rating Calculator популярен среди организаций благодаря своей доступности и универсальности. Его часто используют в сочетании с другими стандартами OWASP, такими как OWASP Top 10 и ASVS, для более детального анализа безопасности веб-приложений.

Тем не менее, инструмент не лишен ограничений. Во-первых, он предоставляет общие оценки, которые могут не учитывать особенности сложных архитектур и уникальные требования конкретных организаций. Во-вторых, калькулятор не всегда оперативно отражает новые методы атак и появляющиеся угрозы из-за нечастых обновлений. Наконец, оценка параметров в значительной степени зависит от субъективного мнения эксперта, что может приводить к разным результатам при анализе одной и той же уязвимости.

Отметим, что для того, чтобы управление рисками было наиболее эффективным, необходимо акцентировать внимание не только на технических характеристиках возможных уязвимостей, но и на возможностях потенциальных опасностей и злоумышленников.

Разнообразные средства анализа рисков, включая CVSS, EPSS и OWASP, обладают индивидуальными задачами, но при этом усиливают эффективность друг друга. CVSS концентрируется на измерении критичности уязвимости, EPSS занимается прогнозированием возможности её эксплуатации в реальной среде, а OWASP акцентирует внимание на рисках для бизнеса и потенциальных последствиях. Совместное использование данных подходов способствует принятию более взвешенных решений и сокращает расходы на исправление уязвимостей, представляющих минимальную опасность.

2 Установление взаимосвязей пар типа «шаблон атаки — уязвимость» для атак класса «Сканирование TCP-портов»

2.1 Систематизация соответствий между CAPEC-шаблонами атак и эксплуатируемыми ими уязвимостями

Возникновение независимых классификационных подходов, не предусматривающих взаимодействие между собой, стало причиной несогласованности данных. Для обеспечения единства в классификации, необходимо соотнести уязвимость с одним из шаблонов атаки, взятых из международного стандарта CAPEC.

Каждый шаблон атаки – это, по сути, формализованное представление ключевых параметров, связанных с эксплуатацией уязвимости. Он выступает в роли подробного описания методик, используемых злоумышленником для нахождения и последующего использования уязвимостей в разнообразных автоматизированных информационных системах.

Основная задача заключается в установлении взаимосвязи между описанным шаблоном в CAPEC и конкретными слабостями системы, определенными в CWE. Эти слабости, в свою очередь, связаны с конкретными уязвимостями, зарегистрированными в CVE.

Данная работа сосредоточена на классе угроз, охватывающем класс «Сканирование TCP-портов". Этот класс представляет собой серьезную угрозу для информационной безопасности, что требует детального анализа и оценки потенциальных рисков. Название класса атак «Сканирование TCP-портов» предельно ясно описывает природу этих угроз. Атакующий использует стандартные функции транспортного протокола TCP: посылают SYN-запросы, манипулируют флагами (FIN, PSH, URG, NULL и другие), либо устанавливают полное трехстороннее соединение. Цель этих действий – не обмен информацией, а разведка сети и поиск запущенных сервисов. Вместо того, чтобы сразу эксплуатировать обнаруженные уязвимости в системе, злоумышленники анализируют ответы хостов и сетевого оборудования. Полученные данные помогают им создать карту инфраструктуры и выявить перспективные точки

для дальнейших атак. Подходы, описанные в CAPEC-287, CAPEC-303, CAPEC-301, CAPEC-302 и CAPEC-304, являются ярким примером этого типа атак.

В данной работе будут рассмотрены следующие шаблоны атак [13]:

– CAPEC-303 - TCP Xmas Scan;
– CAPEC-287 - TCP SYN Scan;
– CAPEC-301 - TCP Connect Scan;
– CAPEC-302 - TCP FIN Scan;
– CAPEC-304 - TCP Null Scan.

Можно представить выбранные шаблоны атак в виде древовидной структуры, изображенной на рисунке 1 ниже.

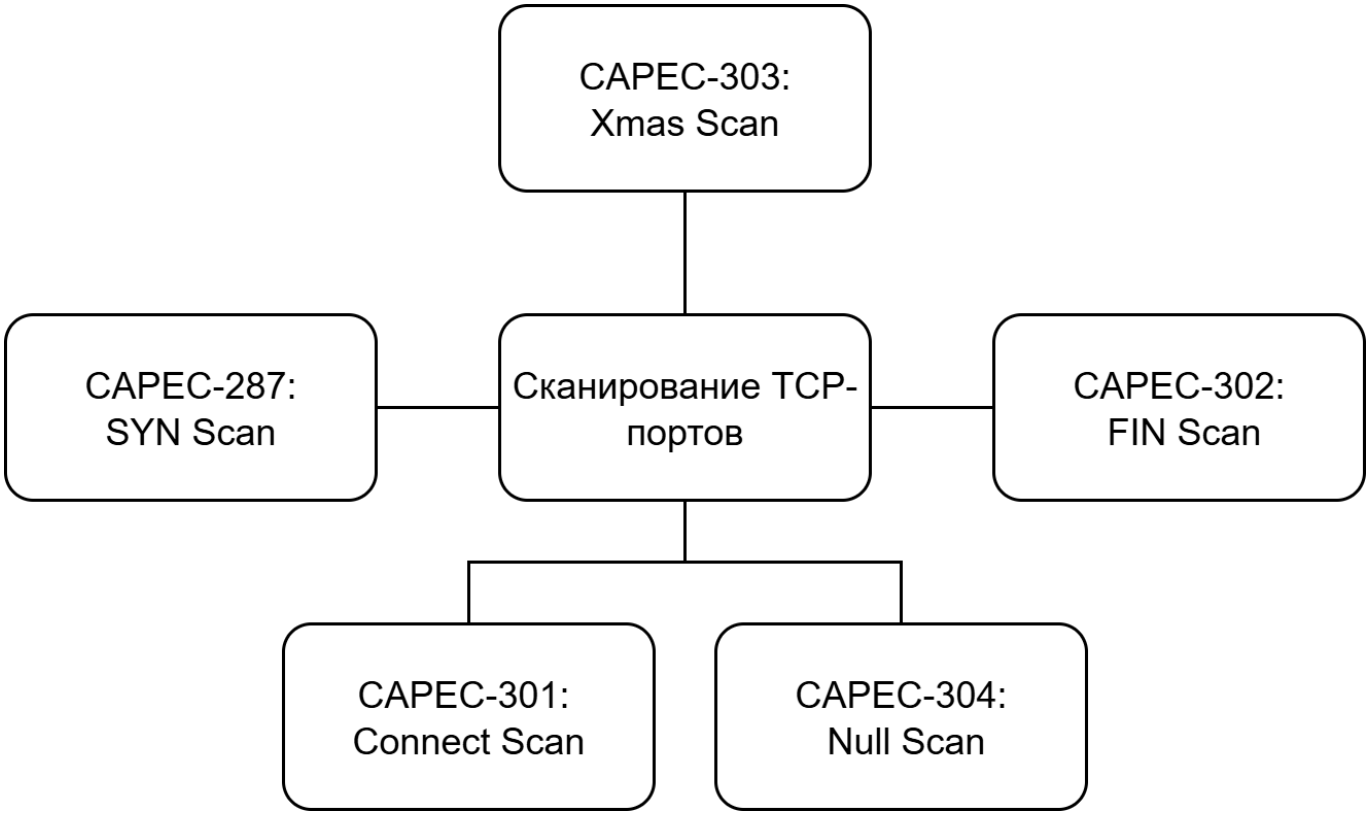


Рисунок 1 – Древовидный граф векторов атаки CAPEC

Для формирования множества уязвимостей, относящихся к каждому шаблону CAPEC, используются данные из банка данных уязвимостей БДУ ФСТЭК.

CAPEC 303 – Xmas Scan. Этот вид атаки опирается на сканирование TCP XMAS для выяснения, закрыты ли порты на целевой системе. С помощью Xmas для определения портов. Если порт открыт на целевой системе, то пакеты будут игнорироваться. Если закрыт, то RST будет отправлен обратно злоумышленнику, запустившему сканирование. Сканирование Xmas было популярно не только из-за его скорости по сравнению с другими сканированиями, но и из-за его сходства с пакетами FIN и ACK, не имеющими состояния, которые могли легко обойти межсетевые экраны без сохранения состояния и фильтры ACL. Паспорт шаблона атаки CAPEC-303 представлен ниже в таблице 1.

Таблица 1 – Паспорт шаблона атаки CAPEC-303

Идентификатор системы CAPEC	CAPEC-303 TCP XMAS Scan	
Описание шаблона атаки	Злоумышленник использует сканирование TCP XMAS, чтобы определить, закрыты ли порты на целевой машине. Этот тип сканирования выполняется путем отправки сегментов TCP со всеми возможными флагами, установленными в заголовке пакета, генерируя пакеты, которые являются незаконными на основе.	
Тип атаки	Сбор и анализ информации	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200	Не рекомендован для использования с реальными уязвимостями

На основе информации, собранной из баз данных выделены CWE и сопоставленные с ними CVE-уязвимости. Опираясь на эти данные, соберем подходящие уязвимости в таблицу 2.

Таблица 2 – Соотношение CAPEC-303 типа «атака – уязвимость»

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
CAPEC-303	TPC Xmas Scan	CWE-200	CVE-2022-1012
			CVE-2023-45236
			CVE-2018-15473
			CVE-2022-21985
			CVE-2020-17133

Продолжение таблицы 2

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
			CVE-2023-36905
			CVE-2025-21214
			CVE-2024-21183
			CVE-2018-8444
			CVE-2024-36036
			CVE-2022-38026
			CVE-2021-40454
			CVE-2022-39283
			CVE-2024-29960
			CVE-2024-39884
			CVE-2021-28328
			CVE-2022-21921
			CVE-2023-32037
			CVE-2024-43609
			CVE-2023-38160
			CVE-2023-36722
			CVE-2020-25718
			CVE-2023-36052
			CVE-2020-1263
			CVE-2024-25728
			CVE-2024-45336
			CVE-2021-31186
			CVE-2024-42256
			CVE-2019-0839
			CVE-2021-25122
			CVE-2018-93401

Используя сведения, изложенные в таблице уязвимостей, требуется подготовить паспорта, описывающие каждую из них. Структура паспорта уязвимости предусматривает фиксацию следующих параметров: идентификатор CVE, соответствующий код CWE, базовый вектор CVSS, определяющий степень угрозы, текущий статус верификации уязвимости, сведения о наличии эксплойта, рекомендации по устранению уязвимости, а также информацию об участии уязвимости в реальных инцидентах. Данный формат гарантирует унифицированное представление данных, необходимое для дальнейшего применения в рамках установленной методологии. Паспорт уязвимости представлен в таблице 3.

Таблица 3 – Паспорт уязвимости CVE-2018-15473

Идентификатор уязвимости	CVE-2018-15473 Уязвимость средства криптографической защиты OpenSSH связана с различной реакцией сервера на запросы аутентификации при наличии и отсутствии соответствующих учетных записей. Эксплуатация уязвимости может позволить нарушителю выявить существующие записи пользователей путем отправки специально сформированных запросов аутентификации
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена в ходе исследований
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

CAPEC-287. Данный вариант атаки реализуется на основе традиционного механизма установления TCP-соединения (трёхстороннего обмена), но характеризуется тем, что данный метод получил название «полуоткрытого» сканирования. Суть в том, что злоумышленник не доводит процесс до конца, отправляя только пакет SYN. Действия сводятся к отправке последовательности SYN-запросов на порты целевого хоста с последующим анализом ответов: SYN/ACK – порт открыт, RST – порт закрыт, отсутствие ответа или ICMP – порт отфильтрован. Поскольку «рукопожатие» не завершается, SYN-сегменты обычно проходят через брандмауэр. Скорость сканирования может достигать нескольких тысяч запросов в секунду, так как они выглядят как вполне корректные запросы на соединение. Метод позволяет определить три ключевых состояния порта, минимизируя обнаружение за счет небольшого объема трафика и незавершенности сессии. Паспорт шаблонаCAPEC-287 приведен н в таблице 4.

Таблица 4 – Паспорт шаблона атаки CAPEC-287

Идентификатор системы CAPEC	CAPEC-287 TCP SYN Scan	
Описание шаблона атаки	Злоумышленник использует SYN-сканирование для определения состояния портов на удаленном хосте. SYN-сканирование является наиболее распространенным типом сканирования портов, которое используется из-за многочисленных преимуществ и небольшого количества недостатков.	
Тип атаки	Сбор и анализ информации	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200	Не рекомендован для использования с реальными уязвимостями

Ниже в таблице 5 представлен шаблон атаки CAPEC-287, включающий виды ошибок и соответствующие им уязвимости.

Таблица 5 – Соотношение CAPEC-287 типа «атака – уязвимость»

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
CAPEC-287	TCP SYN Scan	CWE-200	CVE-2022-1012
			CVE-2020-11898
			CVE-2020-12802
			CVE-2020-2584
			CVE-2021-3449
			CVE-2021-34749
			CVE-2024-21243
			CVE-2022-11898
			CVE-2022-27672
			CVE-2020-25718
			CVE-2022-30556
			CVE-2023-28290
			CVE-2022-36074
			CVE-2024-0753
			CVE-2018-14782
			CVE-2018-15598
			CVE-2020-2838
			CVE-2019-0977
			CVE-2018-16862
			CVE-2020-2743
			CVE-2020-0658
			CVE-2018-10729
			CVE-2018-8506
			CVE-2018-15433

Используя данные из таблицы, необходимо заполнить паспорт уязвимости, подходящей под шаблон CAPEC-287. Паспорт уязвимости, подходящей под CAPEC-287, представлен в таблице 6. Остальные паспорта уязвимостей приведены в приложении А.

Таблица 6 – Паспорт уязвимости CVE-2023-45236

Идентификатор уязвимости	CVE-2021-3449 Уязвимость реализации протокола TLS библиотеки OpenSSL связана с ошибками разыменования указателей. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании с помощью специально созданного вредоносного сообщения «ClientHello»
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,3) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

CAPEC-301 – TCP Connect Scan. Описание шаблона выглядит таким образом: киберпреступник с помощью TCP Connect Scan (CAPEC-301), использует полное трёхстороннее рукопожатие по спецификации протокола. Злоумышленник устанавливает полноценное соединение (SYN → SYN/ACK → ACK), после чего сразу разрывает его, что приводит к значительному объёму передаваемых пакетов и генерирует «шум» в системных журналах, легко обнаруживаемый IDS/IPS. Из-за необходимости завершать рукопожатие этот метод отличается медленной и методичной работой, поэтому обычно применяется для проверки ограниченного списка портов и редко используется для масштабного сканирования — полное обследование всех портов может занять от нескольких часов до нескольких дней. Данные базы CAPEC о TCP Connect Scan аккумулированы в таблице 7

Таблица 7 – Паспорт шаблона атаки CAPEC-301

Идентификатор системы CAPEC	CAPEC-301	
Описание шаблона атаки	Злоумышленник использует полное TCP-подключение, чтобы определить, открыт ли порт на целевой системе. Процесс сканирования включает в себя выполнение «трехстороннего рукопожатия» с удаленным портом и сообщает о закрытом порте, если полное рукопожатие не может быть установлено. Преимущество сканирования TCP-подключения заключается в том, что оно работает против любого стека TCP/IP.	
Тип атаки	Сбор и анализ информации	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200	Соотношение типа ошибки CWE и статуса типа ошибки CWE

Для наглядного сопоставления уязвимостей CVE и шаблонов CWE необходимо заполнить таблицу 8

Таблица 8 – Соотношение CAPEC-301 типа «атака – уязвимость»

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
CAPEC-301	TCP Connect Scan	CWE-200	CVE-2019-0688
			CVE-2021-28442
			CVE-2021-45486
			CVE-2021-39203
			CVE-2024-11376
			CVE-2023-39326
			CVE-2023-36438
			CVE-2023-6332
			CVE-2023-41749
			CVE-2021-4160
			CVE-2018-8481
			CVE-2018-8472
			CVE-2022-32221
			CVE-2018-8481
			CVE-2023-33952

Продолжение таблицы 8

CAPEC-301	TCP Connect Scan	CWE-200	CVE-2023-20172
			CVE-2023-21741
			CVE-2019-0537
			CVE-2019-0536
			CVE-2019-0549
			CVE-2019-0545
			CVE-2019-0561
			CVE-2019-0560
			CVE-2019-0559
			CVE-2023-38133

На основании таблиц выделим уязвимости CAPEC – 301 и составим их паспорта (пример – в таблице 9).

Таблица 9 – Паспорт уязвимости CVE-2019-0688

Идентификатор уязвимости	CVE-2019-0688 Уязвимость реализации протокола TCP/IP операционной системы Windows связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, оказать воздействие на конфиденциальность защищаемой информации при помощи специально сформированных фрагментированных IP-пакетов
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

TCP FIN Scan – CAPEC-302. Злоумышленник применяет сканирование TCP FIN для определения состояния портов на атакуемом узле – закрыты они или открыты. Этот метод сканирования подразумевает отправку TCP-сегментов, в заголовке которых выставлен бит FIN. Согласно стандарту RFC 793, если на открытый порт приходит не соответствующий ему сегмент TCP, он подлежит отбрасыванию. В то же время

на закрытые порты такие сегменты должны отвечать пакетом RST. Подобное поведение даёт злоумышленнику возможность просканировать закрытые порты.

Рассматриваемый шаблон атаки базируется на методе TCP FIN Scan, но отличается тем, что злоумышленник не завершает традиционную процедуру трёхстороннего рукопожатия, отправляя на целевые порты лишь TCP-пакеты с установленным флагом FIN. Используя базу знаний CAPEC, структурируем данные о FIN Scan в паспорте (таблица 10).

Таблица 10 – Паспорт шаблона CAPEC-302

Идентификатор системы CAPEC	CAPEC-302 TCP FIN Scan	
Описание шаблона атаки	Злоумышленник использует сканирование TCP FIN, чтобы определить, закрыты ли порты на целевой машине. Этот тип сканирования выполняется путем отправки сегментов TCP с установленным битом FIN в заголовке пакета.	
Тип атаки	Сбор и анализ информации	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200	Не рекомендован для использования с реальными уязвимостями

Ниже в таблице 11 представлен вектор атаки CAPEC-302, включающий виды ошибок и соответствующие им уязвимости.

Таблица 11 – Соотношение CAPEC-302 типа «атака – уязвимость»

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
1	2	3	4
CAPEC-302	TCP FIN Scan	CWE-200	CVE-2024-21313
			CVE-2019-9824
			CVE-2018-5115
			CVE-2018-15919
			CVE-2019-0848
			CVE-2019-1108

Продолжение таблицы 11

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
CAPEC-302	TCP FIN Scan	CWE-200	CVE-2019-0977
			CVE-2019-6806
			CVE-2020-3182
			CVE-2020-2889
			CVE-2020-3259
			CVE-2021-33783
			CVE-2018-2587
			CVE-2022-29244
			CVE-2019-0021
			CVE-2018-15598
			CVE-2018-10729
			CVE-2018-8366
			CVE-2018-16862
			CVE-2018-3989
			CVE-2023-29355
			CVE-2025-21242
			CVE-2022-46698
			CVE-2018-7848

Паспорт уязвимости взаимосвязанной с шаблоном CAPEC-302 представлен в таблице 12. Остальные паспорта уязвимостей приведены в приложении А.

Таблица 12 – Паспорт уязвимости CVE-2020-3259

Идентификатор уязвимости	CVE-2020-3259 Уязвимость веб-интерфейса микропрограммного обеспечения межсетевых экранов Cisco Adaptive Security Appliance (ASA) и Configure Firepower Threat Defense (FTD) связана с ошибками обработки объектов в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Шаблон с идентификатором 304 в базе данных имеет следующее описание: атака базируется на применении TCP NULL-сканирования для выявления статуса портов на атакуемом узле — закрыты они или нет. Суть метода заключается в отправке сегментов TCP, у которых отсутствуют флаги, то есть пакеты, противоречащие стандарту RFC 793. В соответствии с RFC 793, любые TCP-сегменты без установленных флагов, предназначенные для открытых портов, должны игнорироваться. В то же время, для закрытых портов ответ должен быть представлен пакетом RST. Такое поведение позволяет злоумышленнику, отправляя специально сформированные пакеты, нарушающие протокол (несинхронизированные или запрещенные TCP Control Blocks), обнаруживать закрытые порты по наличию RST-пакетов в ответ.

Данные источника CAPEC о TCP NULL Scan аккумулированы в таблице 13.

Таблица 13 – Паспорт шаблона CAPEC-304

Идентификатор системы CAPEC	CAPEC-304	
Описание шаблона атаки	Злоумышленник использует сканирование TCP NULL, чтобы определить, закрыты ли порты на целевой машине. Этот тип сканирования выполняется путем отправки сегментов TCP без флагов в заголовке пакета, что создает пакеты, которые являются незаконными на основе RFC 793.	
Тип атаки	Сбор и анализ информации	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200	Не рекомендован для использования с реальными уязвимостями

Ниже в таблице 14 представлен вектор атаки CAPEC-304, включающий виды ошибок и соответствующие им уязвимости.

Таблица 14 – Соотношение CAPEC-304 типа «атака – уязвимость»

Идентификатор шаблона атаки	Название шаблона атаки	Типы ошибок, относящиеся к шаблону	Взаимосвязанные уязвимости
1	2	3	4
CAPEC-304	TCP Null Scan	CWE-200	CVE-2018-5115
			CVE-2023-0027
			CVE-2023-36706
			CVE-2018-20445
			CVE-2017-7484
			CVE-2020-1744
			CVE-2021-34500
			CVE-2021-43236
			CVE-2021-28324
			CVE-2021-28325
			CVE-2020-17140
			CVE-2023-28175
			CVE-2023-0027
			CVE-2023-36706
			CVE-2018-20445
			CVE-2017-7484
			CVE-2020-1744
			CVE-2021-34500
			CVE-2021-43236
			CVE-2021-28324
			CVE-2021-28325
			CVE-2020-17140
			CVE-2023-28175
			CVE-2023-32681
			CVE-2019-0004
			CVE-2018-14782
			CVE-2018-8351
			CVE-2018-4171
			CVE-2018-20389
			CVE-2018-18007
			CVE-2018-18008
			CVE-2019-0549
			CVE-2019-0545
			CVE-2019-0561

Паспорт одной из уязвимостей CAPEC-304 указан ниже в таблице 15.

Таблица 15 – Паспорт уязвимости CVE-2021-43236

Идентификатор уязвимости	CVE-2021-43236 Уязвимость службы очереди сообщений Microsoft Message Queuing (MSMQ) операционной системы Microsoft Windows связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Исследование, проведенной на основе сведений из баз знаний MITRE, позволило детально описать спектр взаимосвязей между уязвимостями CVE и CWE.

2.2 Сопоставление полученных взаимосвязей с матрицей MITRE ATT&CK

В данном разделе сценарий атаки необходимо представить в виде последовательности микромоделей. Суть методики состоит в том, что для каждой тактики в классификации ATT&CK можно построить вероятностную модель эксплуатации уязвимостей с учетом оценок их риск-калькуляторов. Такой подход позволяет описать траекторию атаки на автоматизированную информационную систему и оценить вероятность наступления ущерба определенной величины через реализацию единичной уязвимости .

Далее необходимо подобрать тактики, наиболее подходящие под особенности шаблонов класса атак «Сканирование TCP-портов».

Цель злоумышленника при использовании «рождественского сканирования» (CAPEC-303) состоит в незаметном обходе фильтров межсетевого экранирования с

помощью использования всех флагов, получения базы возможных уязвимостей сетевых сервисов, использования этих уязвимостей для первоначального доступа к системе, получения с их помощью учетных данных и использования этих данных для движения вглубь системы. В таблице 16 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-303.

Таблица 16 – Соотнесение техник и тактик с уязвимостями CAPEC-303

CAPEC-303: TCP Xmas Scan		
Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
1	2	3
TA0043: Разведка	T1595	CVE-2022-1012 CVE-2023-45236 CVE-2018-15473
TA0001: Первоначальный доступ	T1199	CVE-2022-21985 CVE-2020-17133 CVE-2023-36905
TA0005: Предотвращение обнаружения	15622	CVE-2025-21214 CVE-2024-21183
TA0006: Получение учетных данных	T1552	CVE-2018-8444
TA0007: Обнаружение	T1082	CVE-2024-36036 CVE-2022-38026 CVE-2021-40454
	T1016	CVE-2022-39283 CVE-2024-29960 CVE-2024-39884
	T1087	CVE-2021-28328 CVE-2022-21921
TA0008: Перемещение внутри периметра	T1021.002	CVE-2023-32037 CVE-2022-30134 CVE-2024-43609

Цель злоумышленника при использовании TCP SYN Scan (CAPEC-287) состоит в скрытном и эффективном определении открытых портов через полуоткрытое рукопожатие с последующим сбором детальной информации о сетевых службах, которая затем используется для эксплуатации уязвимостей, получения учётных данных и дальнейшего продвижения с возможностью обхода систем защиты. В таблице 17 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-287.

Таблица 17 – Соотнесение техник и тактик с уязвимостями CAPEC-287

CAPEC-287: TCP SYN Scan		
Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
1	2	3
TA0043: Разведка	T1595	CVE-2022-1012 CVE-2020-11898
TA0005: Предотвращение обнаружения	T1562.004	CVE-2020-12802 CVE-2020-2584
	T1036	CVE-2021-3449 CVE-2021-34749
TA0006: Получение учетных данных	T1040	CVE-2024-21243 CVE-2022-11898 CVE-2022-27672
	T1212	CVE-2022-30556 CVE-2022-39282
TA0007: Обнаружение	T1040	CVE-2020-25718
TA0008: Перемещение внутри сети	T1210	CVE-2023-33952 CVE-2024-0753
TA0011: Организация Управления	T1071	CVE-2018-14782 CVE-2018-15598
TA00010: Эксфильтрация данных	T1048	CVE-2020-2838 CVE-2019-0977

Для шаблона атаки CAPEC-301 «TCP Connect Scan» выбор тактик и техник выстроен так, чтобы последовательно пройти все ключевые этапы, от разведки до разрушительного воздействия, с учетом необходимости полного соединения с целевой машиной и портом.

В таблице 18 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-301.

Таблица 18 – Соотнесение техник и тактик с уязвимостями CAPEC-301

CAPEC-301: TCP Connect Scan		
Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
TA0043: Разведка	T1590.004	CVE-2019-0688 CVE-2021-28442
	T1595	CVE-2021-45486 CVE-2021-39203
TA0001: Первоначальный доступ	T1205	CVE-2021-39203 CVE-2024-11376 CVE-2023-39326
TA0005: Предотвращение обнаружения	T1562	CVE-2024-21243 CVE-2022-11898
TA0007: Обнаружение	T1046	CVE-2023-35952
TA0008: Перемещение внутри периметра	T1563	CVE-2023-6332 CVE-2021-4160
	T1210	CVE-2022-32221
TA0040: Деструктивное воздействие	T1565	CVE-2023-20172 CVE-2023-38133

Соотношение техник и тактик с уязвимостями подобрано исходя возможных целей преследуемых киберпреступником. В таблице 19 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-302.

Таблица 19 – Соотнесение техник и тактик с уязвимостями CAPEC-302

CAPEC-302: TCP FIN Scan		
Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
TA0043: Разведка	T1595	CVE-2018-15919 CVE-2019-0848 CVE-2019-1108

Продолжение таблицы 19

Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
TA0001: Первоначальный доступ	T1133	CVE-2018-15919 CVE-2019-0848 CVE-2019-1108
TA0005: Предотвращение обнаружения	T1070	CVE-2019-0977 CVE-2019-6806 CVE-2020-3182
TA0007: Обнаружение	T1046	CVE-2020-2889 CVE-2020-3259 CVE-2021-33783
	T1016	CVE-2018-2587 CVE-2022-29244 CVE-2023-29355
TA0040: Деструктивное воздействие	T1485	CVE-2025-21242 CVE-2022-46698
	T1499	CVE-2018-7848

Соотношение техник и тактик для Null Scan выбирается с учетом того, что система принимает пакеты без специализированных флагов, а не просто их отбрасывает. Принимая во внимание эту особенность, мы получаем соотношение, представленное в таблице. В таблице 20 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-302.

Таблица 20 – Соотнесение техник и тактик с уязвимостями CAPEC-304

CAPEC-304: TCP Null Scan		
Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
TA0043: Разведка	T1595	CVE-2022-1012 CVE-2023-45236 CVE-2018-15473
TA0001: Первоначальный доступ	T1133	CVE-2019-0977 CVE-2019-0608 CVE-2020-3182
TA0008: Перемещение внутри периметра	T1210	CVE-2022-32221

Продолжение таблицы 20

Тактика	Техника	Уязвимости, вероятно эксплуатируемые техникой
TA0007: Обнаружение	T1016	CVE-2018-15919 CVE-2024-21243
	T1046	CVE-2019-0408 CVE-2019-1108
TA0010: Сбор данных	T1048	CVE-2022-11898
	T1041	CVE-2021-43236 CVE-2021-34500

Разработанные соответствия дают возможность формировать базу для создания детализированных микромоделей, которые отражают конкретные реализации техник сценариев. Эти модели учитывают вероятные риски и возможные последствия атак, что способствует более точной оценке угроз и выработке мер защиты.

3 Расчет и анализ параметров реализации сформированных сценариев атак

3.1 Определение критичности эксплуатируемых уязвимостей

В этом разделе предложен подход к оценке критичности эксплуатируемых уязвимостей. Ключевое внимание уделено метрикам, полученными риск-калькуляторами, с последующим расчетом вероятности их реализации [32]. Применение этих данных способствует построению более реалистичной модели возможных последствий атак. Это, в свою очередь, позволяет разрабатывать более обоснованные и эффективные варианты снижения рисков.

В первую очередь, проведен сравнительный анализ результатов, полученных с использованием нескольких известных калькуляторов, таких как: CVSS версий 3.1 и 4.0, EPSS и OWASP, который представлен в таблице 21 для шаблона атаки.

Таблица 21 – Расчет калькуляторов уязвимостей шаблона атаки CAPEC-303

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2022-1012	8,2	8,6	0,407	5,375
CVE-2023-45236	5,3	4,8	0,376	5,875
CVE-2018-15473	7,5	8	0,90473	5
CVE-2022-21985	5,5	5,8	0,321	5
CVE-2020-17133	6,5	6,7	0,10386	5,875
CVE-2023-36905	5,5	5,5	0,3507	4,875
CVE-2025-21214	4,2	3,9	0,71	4,625
CVE-2024-21183	7,5	7,7	0,232	4,875
CVE-2018-8444	7	7,2	0,3758	4,125
CVE-2024-36036	4,2	3,9	0,37	5
CVE-2022-38026	7,8	8,3	0,179	3,625
CVE-2021-40454	5,5	5,5	0,145	4,75
CVE-2022-39283	5,9	5,8	0,00162	5,375
CVE-2024-29960	6,8	6,3	0,00091	4,125
CVE-2024-39884	7,5	7	0,114	5,75
CVE-2021-28328	6,5	6,9	0,11531	3,5

Продолжение таблицы 21

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2022-21921	4,4	4	0,1585	4,25
CVE-2023-32037	6,5	7	0,169	5,25
CVE-2022-30134	7,6	8	0,2141	3,875
CVE-2024-43609	6,5	6,7	0,16726	5,625

Для шаблона атаки CAPEC-287 проведен расчет оценки рисков по калькулятору, который представлен в таблице 22.

Таблица 22 – Расчет калькуляторов уязвимостей шаблона атаки CAPEC-287

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2022-1012	8,2	9,2	0,383	5,375
CVE-2020-11898	9,1	8,9	0,67763	6,25
CVE-2020-12802	5,3	6,3	0,401	3,875
CVE-2020-2584	4,4	5,4	0,187	4,5
CVE-2021-3449	5,9	6,9	0,13858	3,125
CVE-2021-34749	8,6	9,6	0,44	6,75
CVE-2024-21243	8,1	8,8	0,42	5
CVE-2022-11898	7,4	8,4	0,12	4,625
CVE-2022-27672	4,7	5,7	0,115	3,25
CVE-2020-25718	7,5	8,5	0,125	5,875
CVE-2022-30556	7,5	8,5	0,86	4,75
CVE-2023-28290	5,4	9,8	0,141	6,125
CVE-2022-36074	7,5	7,7	0,523	3,5
CVE-2024-0753	6,5	7,5	0,252	5,625
CVE-2018-14782	7,5	8,1	0,343	4,75
CVE-2018-15598	8,6	8,5	0,404	4,75
CVE-2020-2838	8,6	8,9	0,1621	6,125
CVE-2019-0977	6,5	6,9	0,7622	3,25

Исследование оценки рисков уязвимостей, соответствующих шаблону атаки CAPEC-301, представлен в таблице 23.

Таблица 23 – Расчет калькуляторов уязвимостей шаблона атаки CAPEC-301

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2019-0688	5,3	4,9	0,10301	5,375
CVE-2021-28442	6,5	7	0,13694	5,125
CVE-2021-45486	5,9	5,5	0,1	3,125
CVE-2021-39203	6,5	6,9	0,724	4,5
CVE-2024-11376	5,5	5,5	0,4321	4,125
CVE-2023-39326	5,3	5,2	0,14	3,625
CVE-2023-36438	7,5	7,7	0,38	5,75
CVE-2023-6332	4,1	4,5	0,682	4,5
CVE-2023-41749	7,5	7,6	0,6	5
CVE-2021-4160	5,9	6,2	0,264	3,75
CVE-2022-32221	9,8	9,7	0,759	4,125
CVE-2023-33952	5,3	5,2	0,8	5,375
CVE-2023-20172	4,9	4,5	0,116	4,75
CVE-2023-21741	7,1	7,5	0,864	5,625
CVE-2023-38133	6,5	6,9	0,333	5,375

Полученные результаты оценки рисков уязвимостей для шаблона атаки CAPEC-302, представлены в таблице 24.

Таблица 24 – Расчет калькуляторов уязвимостей шаблона атаки CAPEC-302

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-21313	5,3	5,1	0,101	5,5
CVE-2019-9824	5,5	5,5	0,106	5,375
CVE-2018-5115	5,3	5,3	0,153	6,125
CVE-2018-15919	5,3	5,1	0,138	5,625
CVE-2019-0848	4,7	4,8	0,96	3,75
CVE-2019-1108	6,5	6,6	0,2	4

Продолжение таблицы 24

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2019-0977	6,5	6,6	0,076	3,125
CVE-2019-6806	7,5	7,2	0,34	3,25
CVE-2020-3182	4,3	3,9	0,208	4,375
CVE-2020-2889	5,3	5,6	0,71	5,625
CVE-2020-3259	7,5	7,1	0,529	6,5
CVE-2021-33783	6,5	6	0,194	6,125
CVE-2018-2587	6,5	6,2	0,12	3,125
CVE-2022-29244	7,2	7,1	0,717	4,625
CVE-2023-29355	7,5	7,9	0,11	3,875
CVE-2025-21242	5,9	5,8	0,111	4,75
CVE-2022-46698	6,5	6,4	0,325	3,5
CVE-2018-7848	7,5	7,6	0,1323	3,5

Проведенный расчет оценки рисков для шаблона CAPEC-304 с использованием калькуляторов представлен в таблице 25.

Таблица 25 – Расчет калькуляторов уязвимостей шаблона атаки CAPEC-304

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2018-5115	7,7	7,7	0,114	4,5
CVE-2023-0027	7,1	7	0,144	3,625
CVE-2023-36706	6,1	6,3	0,62	5,875
CVE-2018-20445	5,3	4,8	0,37	4,875
CVE-2017-7484	9,8	9,3	0,456	5,75
CVE-2020-1744	7,5	7,8	0,189	3
CVE-2021-34500	9,8	9,3	0,18	5,5
CVE-2021-43236	9,8	10	0,333	3,875
CVE-2021-28324	7,5	7,1	0,78	3,75
CVE-2021-28325	6,5	6,1	0,124	6,5
CVE-2020-17140	6,5	6,8	0,196	3,75
CVE-2023-28175	7,5	7,9	0,941	4,5

Продолжение таблицы 25

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2023-32681	5,3	4,8	0,155	3,375
CVE-2018-5115	7,7	7,7	0,142	4,5
CVE-2023-0027	7,1	7	0,144	3,625
CVE-2023-36706	6,1	6,3	0,622	5,875
CVE-2018-20445	5,3	4,8	0,37	4,875

Ввиду того, что указанные системы оценки используют различные ш диапазоны значений, требуется предварительная нормализация данных. Для приведения оценок к единому масштабу нормализация рассчитывается с помощью формулы [32] (1):

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}} \quad (1)$$

где S_{norm} – нормализованная оценка калькулятора;

S – оценка калькулятора;

S_{max} – максимальная возможная оценка калькулятора;

S_{min} – минимальная возможная оценка калькулятора.

Результаты нормализации для шаблона атаки CAPEC 303 занесены в таблицу 26.

Таблица 26 – Нормализованные значения калькуляторов уязвимостей CAPEC-303

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2022-1012	0,82	0,86	0,407	0,6875
CVE-2023-45236	0,53	0,48	0,376	0,5875

Продолжение таблицы 26

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2018-15473	0,75	0,8	0,90473	0,5
CVE-2022-21985	0,55	0,58	0,321	0,5
CVE-2020-17133	0,65	0,67	0,10386	0,5875
CVE-2023-36905	0,55	0,55	0,3507	0,4875
CVE-2025-21214	0,42	0,39	0,71	0,4625
CVE-2024-21183	0,75	0,77	0,232	0,4875
CVE-2018-8444	0,7	0,72	0,3758	0,4125
CVE-2024-36036	0,42	0,39	0,37	0,5
CVE-2022-38026	0,78	0,83	0,179	0,3625
CVE-2021-40454	0,55	0,55	0,145	0,475
CVE-2022-39283	0,59	0,58	0,162	0,5375
CVE-2024-29960	0,68	0,63	0,91	0,4125
CVE-2024-39884	0,75	0,7	0,114	0,575
CVE-2021-28328	0,65	0,69	0,1531	0,35
CVE-2022-21921	0,44	0,4	0,1585	0,425
CVE-2023-32037	0,65	0,7	0,169	0,525
CVE-2022-30134	0,76	0,8	0,2141	0,3875
CVE-2024-43609	0,65	0,67	0,16726	0,5625

Результаты нормализации для шаблона атаки CAPEC 287 представлены в таблице 27.

Таблица 27 – Нормализованные значения калькуляторов уязвимостей CAPEC-287

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2022-1012	0,82	0,92	0,383	0,5375
CVE-2020-11898	0,91	0,89	0,67763	0,625
CVE-2020-12802	0,53	0,63	0,401	0,3875
CVE-2020-2584	0,44	0,54	0,187	0,45
CVE-2021-3449	0,59	0,69	0,13858	0,3125
CVE-2021-34749	0,86	0,96	0,44	0,675

Продолжение таблицы 27

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2024-21243	0,81	0,88	0,42	0,5
CVE-2022-11898	0,74	0,84	0,12	0,4625
CVE-2022-27672	0,47	0,57	0,115	0,325
CVE-2020-25718	0,75	0,85	0,125	0,5875
CVE-2022-30556	0,75	0,85	0,86	0,475
CVE-2023-28290	0,54	0,98	0,141	0,6125
CVE-2022-36074	0,75	0,77	0,523	0,35
CVE-2024-0753	0,65	0,75	0,252	0,5625

Нормированные оценки уязвимостей для шаблона атаки занесены в таблицу 28.

Таблица 28 – Нормализованные значения калькуляторов уязвимостей CAPEC-301

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2019-0688	5,3	4,9	0,10301	4,375
CVE-2021-28442	6,5	7	0,13694	5,125
CVE-2021-45486	5,9	5,5	0,154	3
CVE-2021-39203	6,5	6,9	0,724	4,5
CVE-2024-11376	5,5	5,5	0,04321	4,125
CVE-2023-39326	5,3	5,2	0,14	3,625
CVE-2023-36438	7,5	7,7	0,38	5,75
CVE-2023-6332	4,1	4,5	0,682	4,5
CVE-2023-41749	7,5	7,6	0,634	5
CVE-2021-4160	5,9	6,2	0,264	3,75
CVE-2022-32221	9,8	9,7	0,759	4,125
CVE-2023-33952	5,3	5,2	0,8	5,375
CVE-2023-20172	4,9	4,5	0,116	4,75
CVE-2023-21741	7,1	7,5	0,00864	5,625
CVE-2023-38133	6,5	6,9	0,00333	5,375

Таблица 29 – Нормализованные значения калькуляторов уязвимостей CAPEC-302

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2024-21313	5,3	5,1	0,101	5,5
CVE-2019-9824	5,5	5,5	0,106	5,375
CVE-2018-5115	5,3	5,3	0,153	6,125
CVE-2018-15919	5,3	5,1	0,1378	5,625
CVE-2019-0848	4,7	4,8	0,996	3,75
CVE-2019-1108	6,5	6,6	0,21411	4
CVE-2019-0977	6,5	6,6	0,07622	3,125
CVE-2019-6806	7,5	7,2	0,0034	3,25
CVE-2020-3182	4,3	3,9	0,00208	4,375
CVE-2020-2889	5,3	5,6	0,771	5,625
CVE-2020-3259	7,5	7,1	0,54329	6,5
CVE-2021-33783	6,5	6	0,1694	6,125
CVE-2018-2587	6,5	6,2	0,161	3,125
CVE-2022-29244	7,2	7,1	0,717	4,625
CVE-2023-29355	7,5	7,9	0,1431	3,875
CVE-2025-21242	5,9	5,8	0,111	4,75
CVE-2022-46698	6,5	6,4	0,325	3,5
CVE-2018-7848	7,5	7,6	0,1323	3,5

Результаты нормализации для шаблона атаки CAPEC 304 представлены в таблице 30.

Таблица 30 – Нормализованные значения калькуляторов уязвимостей CAPEC-304

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2018-5115	7,7	7,7	0,1142	4,5
CVE-2023-36706	6,1	6,3	0,6278	5,875
CVE-2018-20445	5,3	4,8	0,37	4,875
CVE-2017-7484	9,8	9,3	0,456	5,75
CVE-2020-1744	7,5	7,8	0,189	3

Продолжение таблицы 30

Уязвимости	S_{norm}, $CVSS$ 3.1	S_{norm}, $CVSS$ 4.0	S_{norm}, $EPSS$	S_{norm}, $OWASP$
CVE-2021-34500	9,8	9,3	0,186	5,5
CVE-2021-43236	9,8	10	0,333	3,875
CVE-2021-28324	7,5	7,1	0,781	3,75
CVE-2021-28325	6,5	6,1	0,127	6,5
CVE-2020-17140	6,5	6,8	0,1976	3,75
CVE-2023-28175	7,5	7,9	0,938	4,5
CVE-2023-32681	5,3	4,8	0,0155	3,375

Вычисление среднеквадратичного значения основывается на анализе «разброса» нормализованных показателей. Это достигается путем возведения каждого значения в квадрат, суммирования полученных квадратов и последующего деления на общее количество значений [32]. Такой метод подчеркивает значимость крайних величин, давая представление о степени разброса данных. Чувствительность к аномалиям и возможность учёта погрешностей делают его незаменимым при анализе сложных, вариативных систем. С помощью формулы (2) были рассчитаны средние оценки для каждой отдельно взятой уязвимости:

$$S_{final} = \sqrt{\frac{1}{N}\sum_{i=1}^{N} S_{norm,i.}^2} \quad (2)$$

где S_{final} – среднеквадратическая оценка критичности уязвимости;

$S_{norm,i}$- нормализованная оценка калькулятора;

N – количество используемых калькуляторов.

Подсчет среднеквадратичной оценки уязвимостей шаблона атаки CAPEC-303, который представлен в таблице 31.

Таблица 31 – Итоговая среднеквадратичная оценка шаблона атаки CAPEC-303.

Уязвимости	Среднеквадратичная оценка
CVE-2022-1012	0,715944
CVE-2023-45236	0,499458
CVE-2018-15473	0,753498
CVE-2022-21985	0,497981
CVE-2020-17133	0,553928
CVE-2023-36905	0,491337
CVE-2025-21214	0,511494
CVE-2024-21183	0,601432
CVE-2018-8444	0,574409
CVE-2024-36036	0,422907
CVE-2022-38026	0,604307
CVE-2021-40454	0,461424
CVE-2022-39283	0,499913
CVE-2024-29960	0,681461
CVE-2024-39884	0,590788
CVE-2021-28328	0,511014
CVE-2022-21921	0,373948
CVE-2023-32037	0,551517
CVE-2022-30134	0,594474
CVE-2024-43609	0,551313

Затем выполним расчет среднеквадратичной оценки уязвимостей шаблона атаки CAPEC-287, который представлен в таблице 32.

Таблица 32 – Итоговая среднеквадратичная оценка шаблона атаки CAPEC-287.

Уязвимости	Среднеквадратичная оценка
CVE-2022-1012	0,698998435
CVE-2020-11898	0,785812862
CVE-2020-12802	0,497181368
CVE-2020-2584	0,425049703

Продолжение таблицы 32

Уязвимости	Среднеквадратичная оценка
CVE-2021-3449	0,485041407
CVE-2021-34749	0,760004112
CVE-2024-21243	0,68134059
CVE-2022-11898	0,608585707
CVE-2022-27672	0,407630347
CVE-2020-25718	0,64144003
CVE-2022-30556	0,750037499
CVE-2023-28290	0,641684745
CVE-2022-36074	0,622781864
CVE-2024-0753	0,584146867

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-301. Результаты представлены в таблице 33 ниже.

Таблица 33 – Итоговая среднеквадратичная оценка шаблона атаки CAPEC-301.

Уязвимости	Среднеквадратичная оценка
CVE-2019-0688	0,425032
CVE-2021-28442	0,546525
CVE-2021-45486	0,433186
CVE-2021-39203	0,637432
CVE-2024-11376	0,490374
CVE-2023-39326	0,419019
CVE-2023-36438	0,63844
CVE-2023-6332	0,509466
CVE-2023-41749	0,590275
CVE-2021-4160	0,485495

Продолжение таблицы 33

Уязвимости	Среднеквадратичная оценка
CVE-2022-32221	0,813563
CVE-2023-33952	0,458331
CVE-2023-20172	0,408766
CVE-2023-21741	0,729641
CVE-2023-38133	0,569736

Среднеквадратичные оценки уязвимостей для шаблона атаки CAPEC-302, который представлен в таблице 34.

Таблица 34 – Итоговая среднеквадратичная оценка шаблона атаки CAPEC-302.

Уязвимости	Среднеквадратичная оценка
CVE-2024-21313	0,46198
CVE-2019-9824	0,475695
CVE-2018-5115	0,489991
CVE-2018-15919	0,46808
CVE-2019-0848	0,629274
CVE-2019-1108	0,515738
CVE-2019-0977	0,61982
CVE-2019-6806	0,570553
CVE-2020-3182	0,378044
CVE-2020-2889	0,613463
CVE-2020-3259	0,667882
CVE-2021-33783	0,542312
CVE-2018-2587	0,482323
CVE-2022-29244	0,661531
CVE-2023-29355	0,582502
CVE-2025-21242	0,48022
CVE-2022-46698	0,514836
CVE-2018-7848	0,565708

Среднеквадратичные оценки уязвимостей для шаблона атаки CAPEC-304, который представлен в таблице 35.

Таблица 35 – Итоговая среднеквадратичная оценка шаблона атаки CAPEC-304.

Уязвимости	Среднеквадратичная оценка
CVE-2018-5115	0,591891384
CVE-2023-0027	0,535313518
CVE-2023-36705	0,614062108
CVE-2019-0977	0,470599684
CVE-2019-0608	0,768742642
CVE-2020-3182	0,569418699
CVE-2018-15919	0,735256275
CVE-2019-0408	0,745262561
CVE-2019-1108	0,67578684
CVE-2024-21243	0,555105372
CVE-2022-11898	0,515838551
CVE-2021-43236	0,745263
CVE-2021-34500	0,735256
CVE-2021-28324	0,675787
CVE-2021-28325	0,555105
CVE-2020-17140	0,515839
CVE-2023-28175	0,754578865
CVE-2023-32681	0,402927429
CVE-2022-32221	0,813562728

Проведенное исследование позволило комплексно проанализировать уязвимости с учетом различных оценок калькуляторов, что так же повышает обоснованность сформированных мер по снижению риска.

3.2 Расчет рисков успешной реализации сформированных сценариев атак

Для формирования обоснованного множества сценариев атак, необходимо рассмотреть вариативность путей реализации угрозы, включая возможные альтернативные маршруты. Такой подход позволяет определять наиболее опасные траектории движения злоумышленника, что в свою очередь помогает сосредоточится на наиболее уязвимых местах в АИС. Во-первых, необходимо оценить возможность того, что в рамках сценария преступник реализует отдельную техники в рамах комплексного сценария атаки.

Вычисляя вероятность, мы исходим из утверждения, что в рамках комплексного сценария злоумышленник сможет воспользоваться только одной из выявленных уязвимостей [31], а это значит каждая из них рассматривается как независимая альтернатива развития атаки, а итоговое значение принимается равным максимальной критичности среди всех обнаруженных уязвимостей. Вероятность успеха атаки может быть выражена (3):

$$P_i = \frac{K_{ij}}{\sum_{i=1}^{n} K_{ij}}, \tag{3}$$

где K_i – среднеквадратичная оценка критичности i-ой уязвимости;

n – количество уязвимостей, эксплуатируемых техникой.

Во, вторых рассчитать параметр ущерба (4) [34] , который учитывает воздействие уязвимости на различные свойства треугольника CIA. Ущерб оценивается отдельно для каждого вида по шкале {0; 0,2; 0,5}.

$$U = 1 - (1 - U_{\text{к}})\big(1 - U_{\text{д}}\big)\big(1 - U_{\text{ц}}\big)\,, \tag{4}$$

где Uк, Uд, Uц – коэффициенты, характеризующие ущерб конфиденциальности, доступности и целостности соответственно.

Имея необходимые исходные данные, построим таблицу 38 параметров вероятных сценариев реализации шаблона кибератак.

Таблица 36 – Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-303

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой, системы	Критичности эксплуатируемых уязвимостей	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-303	T1595	CVE-2022-1012	0,71594435	0,385753507	0,6
		CVE-2023-45236	0,499457768	0,327328027	0,2
		CVE-2018-15473	0,753497905	0,286918466	0,2
	T1199	CVE-2022-21985	0,497981174	0,317651968	0,2
		CVE-2020-17133	0,553927601	0,372493856	0,2
		CVE-2023-36905	0,491336631	0,309854176	0,2
	T15622	CVE-2025-21214	0,51149444	0,48541272	0,5
		CVE-2024-21183	0,601431677	0,51458728	0,2
	T1552	CVE-2018-8444	0,574408803	1	0,6
	T1082	CVE-2024-36036	0,422906609	0,369269096	0,5
		CVE-2022-38026	0,604306886	0,278356564	0,6
		CVE-2021-40454	0,461424425	0,352374339	0,2
		ИЛИ			
	T1016	CVE-2022-39283	0,499912555	0,348599909	0,5
		CVE-2024-29960	0,681460977	0,277094112	0,6
		CVE-2024-39884	0,590787821	0,374305979	0,2
		ИЛИ			
	T1087	CVE-2021-28328	0,511013603	0,458037423	0,2
		CVE-2022-21921	0,373947607	0,541962577	0,2
	T1021.007	CVE-2023-32037	0,551517452	0,354083862	0,2
		CVE-2022-30134	0,594473519	0,267590866	0,36
		CVE-2024-43609	0,551312561	0,378325272	0,2

В результате получается наглядное визуальное и многообразия возможных альтернативных сценариев в виде графа (рисунок 2).

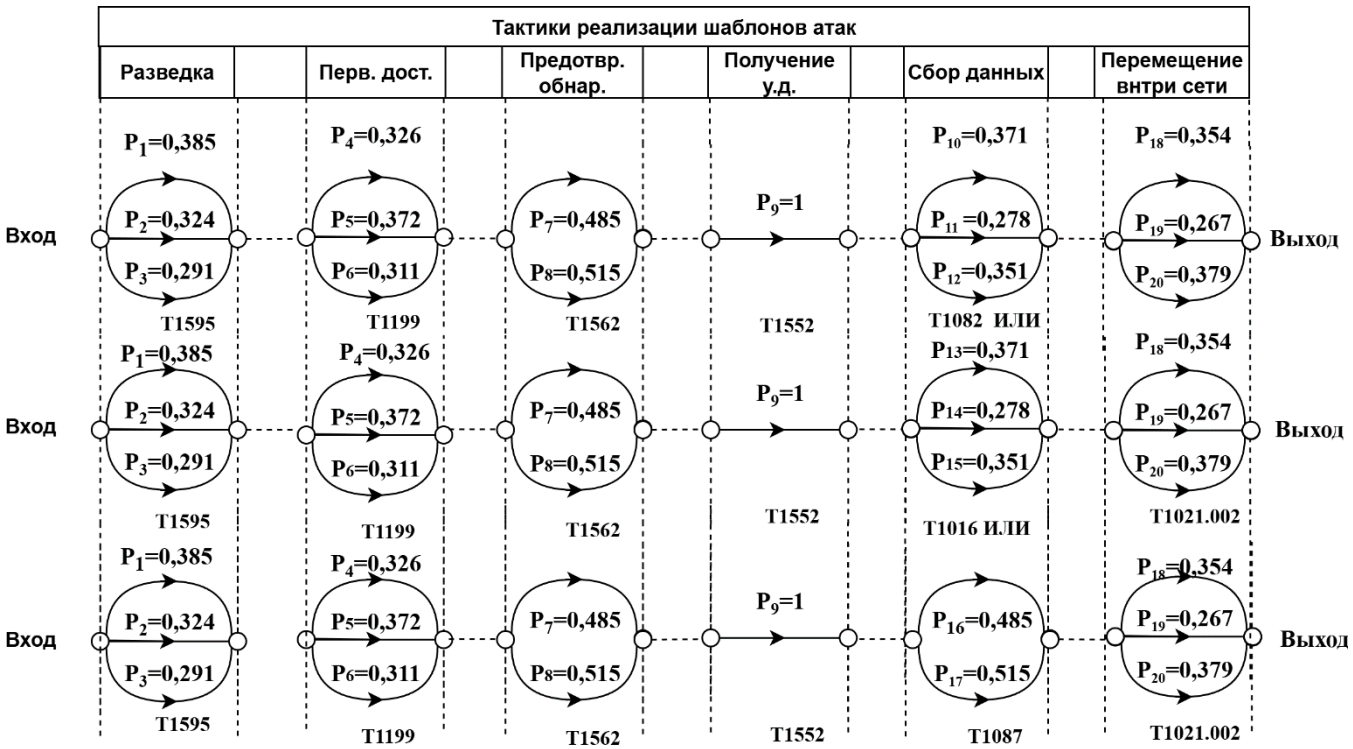


Рисунок 2 – Графовая модель вероятных сценариев реализации CAPEC-303

P_i – Вероятность успешной эксплуатации уязвимости
1 – CVE-2022-1012; 2 – CVE-2023-45236; 3 – CVE-2018-15473;
4 – CVE-2022-21985;5 – CVE-2020-17133; 6 – CVE-2023-36905;
7 – CVE-2025-21214; 8 – CVE-2024-21183; 9 – CVE-2018-8444;
10 – CVE-2024-36036; 11 – CVE-2022-38026; 12 – CVE-2021-40454;
13 – CVE-2022-39283; 14 – CVE-2024-29960; 15 – CVE-2024-39884;
16 – CVE-2021-28328; 17 – CVE-2022-21921; 18 – CVE-2023-32037;
19 – CVE-2022-30134; 20 – CVE-2024-43609

После того, как все параметры, необходимые для каждой компоненты модели, определены, выполняется расчет общего риска, связанного с реализацией выбранного сценария кибератаки. Этот риск вычисляется как произведение вероятностей успешной эксплуатации всех задействованных уязвимостей на суммарный потенциальный ущерб, который система понесет в случае успешного выполнения сценария [31]. По формуле (5) производится вычисление этого ущерба.

$$Risk = \prod_{i}^{k} p_i \times \sum_{j}^{k} U_j, \quad (5)$$

где p_i – вероятность эксплуатации j-ой уязвимости посредством реализации техники Ti;

U_j – ущерб, наносимый атакуемой системе в результате эксплуатации уязвимости $CVEj$ в ходе реализации техники Ti;

k – количество используемых техник.

Теперь вычислим экстремумы для шаблона атаки CAPEC 303. Сценарий содержащий наибольший параметр риска при реализации:

$$Risk_{max} = (0{,}385 * 0{,}372 * 0{,}485 * 0{,}515 * 0{,}379) * \\ * ((0{,}2 * 3) + 0.5 + (0{,}6 * 2)) = 0{,}0312$$

Визуальное отображение данного пути на рисунке 3.

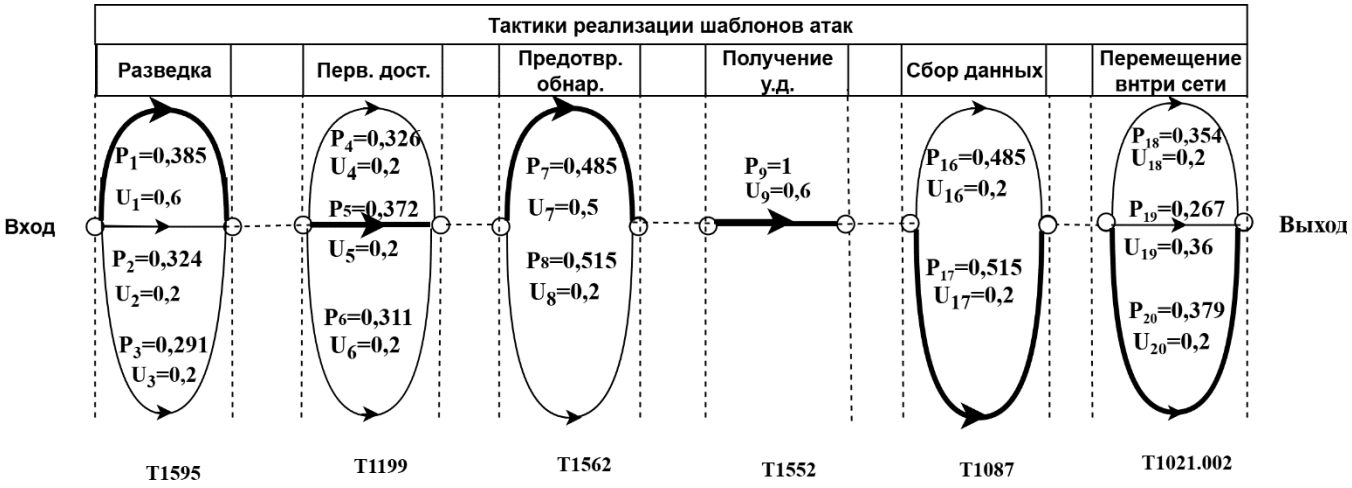


Рисунок 3 — Сценарий реализации CAPEC-303 с наибольшим показателем риска

$$Risk_{min} = (0{,}291 * 0{,}311 * 0{,}515 * 0{,}278 * 0{,}267) * (0{,}2 * 3 + 1{,}2 + 0.36) = \\ = 0{,}0078$$

Визуальное отображение данного пути на рисунке 4.

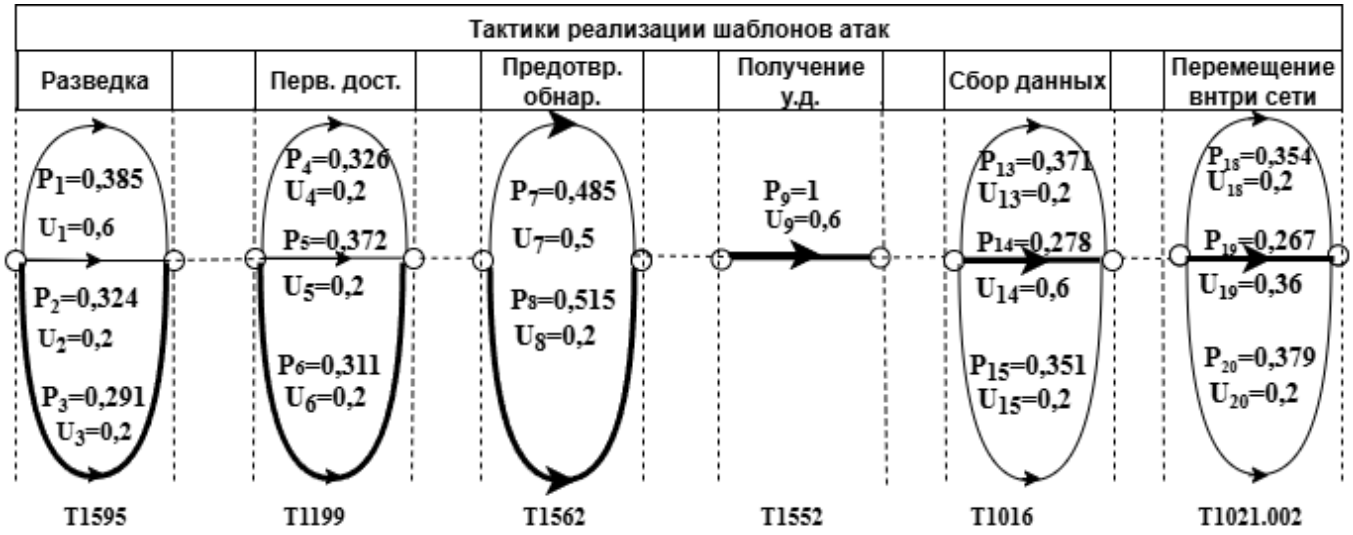


Рисунок 4 — Сценарий реализации CAPEC-303 с наименьшим показателем риска

Наиболее вероятный сценарий находится на рисунке 5

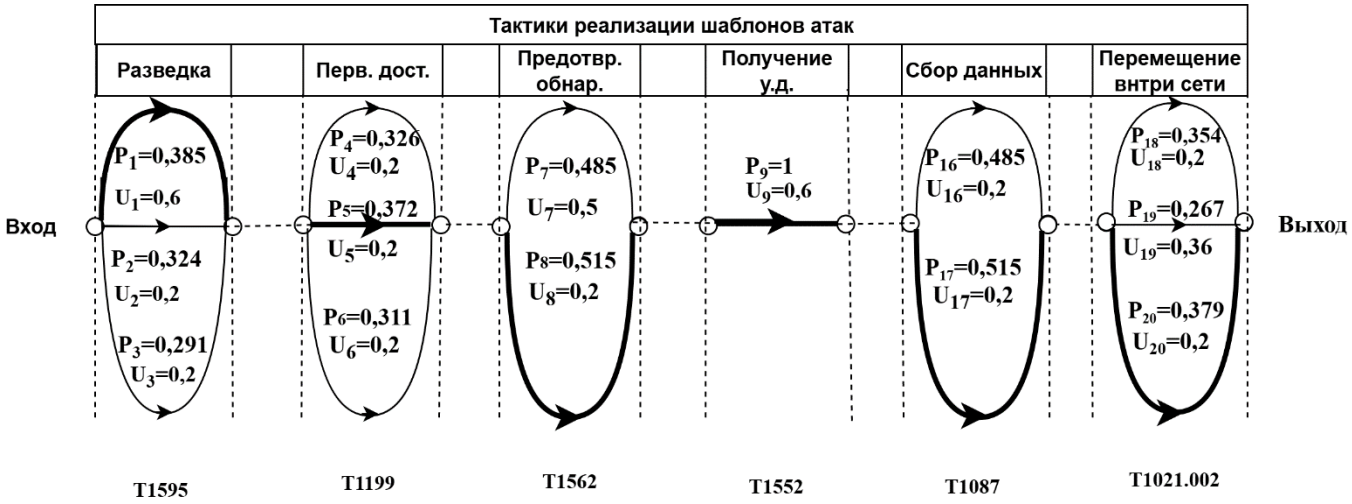


Рисунок 5 — Наиболее вероятный сценарий CAPEC-303

Построим таблицу 37 параметров вероятных сценариев реализации шаблона кибератак CAPEC-287.

Таблица 37 – Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-287

Шаблон атаки на защищаемую систему	Техники уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-287	T1595	CVE-2022-1012	0,698998435	0,470765838	0,6
		CVE-2020-11898	0,785812862	0,529234162	0,875
	T1562.004	CVE-2020-12802	0,497181368	0,539107154	0,2
		CVE-2020-2584	0,425049703	0,460892846	0,5
		ИЛИ			
	T1036	CVE-2021-3449	0,485041	0,389577248	0,75
		CVE-2021-34749	0,760004	0,610422752	0,2
	T1040	CVE-2024-21243	0,681341	0,528201179	0,6
		CVE-2022-11898	0,608586	0,471798821	0,75
		CVE-2022-27672	0,40763	1	0,5
		CVE-2020-25718	0,64144	1	0,875
		ИЛИ			
	T1212	CVE-2022-30556	0,750037499	0,538927578	0,2
		CVE-2023-28290	0,641684745	0,461072422	0,6
	T1210	CVE-2022-36074	0,622781864	0,5160055	0,6
		CVE-2024-0753	0,584146867	0,4839945	0,2
	T1071	CVE-2018-14782	0,624874787	0,47878677	0,2
		CVE-2018-15598	0,680246463	0,52121323	0,2
	T1048	CVE-2020-2838	0,695185705	0,524785636	0,2
		CVE-2019-0977	0,629518435	0,475214364	0,2

Многообразия возможных альтернативных сценариев шаблона кибератаки CAPEC-287 в виде графа (рисунок 6).

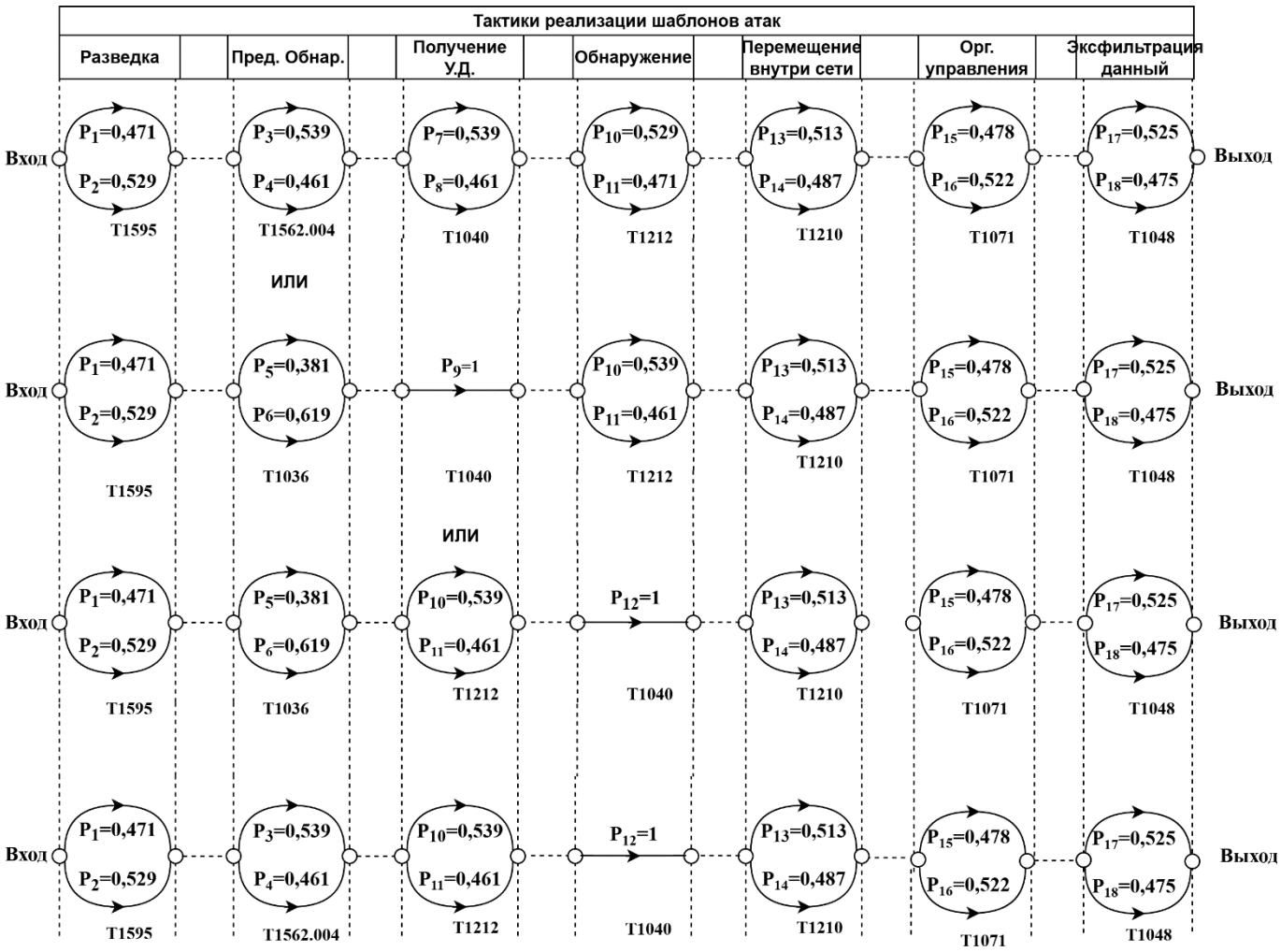


Рисунок 6 — Графовая модель вероятных сценариев реализации CAPEC-287

P_i – Вероятность успешной эксплуатации уязвимости
1 – CVE-2022-1012; 2 – CVE-2020-11898; 3 – CVE-2020-12802;
4 – CVE-2020-2584; 5 – CVE-2021-3449; 6 – CVE-2021-34749;
7 – CVE-2024-21243; 8 – CVE-2022-11898; 9 – CVE-2022-27672;
10 – CVE-2020-25718; 11 – CVE-2022-30556; 12 – CVE-2023-28290;
13 – CVE-2023-28290; 14 – CVE-2024-0753 15 – CVE-2018-14782;
16 – CVE-2018-15598; 17 – CVE-2020-2838; 18 – CVE-2019-0977

Рассчитаем путь с наибольшим показателем риска

$$Risk_{max} = (0{,}529 * 0{,}619 * 0{,}539 * 0{,}513 * 0{,}522 * 0{,}525\ ) * (0{,}875 + 0{,}5 + \\ +0.6 + 0.6 + (0{,}2 * 3)\ ) = 0{,}0788.$$

Данный путь представлен на рисунке 7.

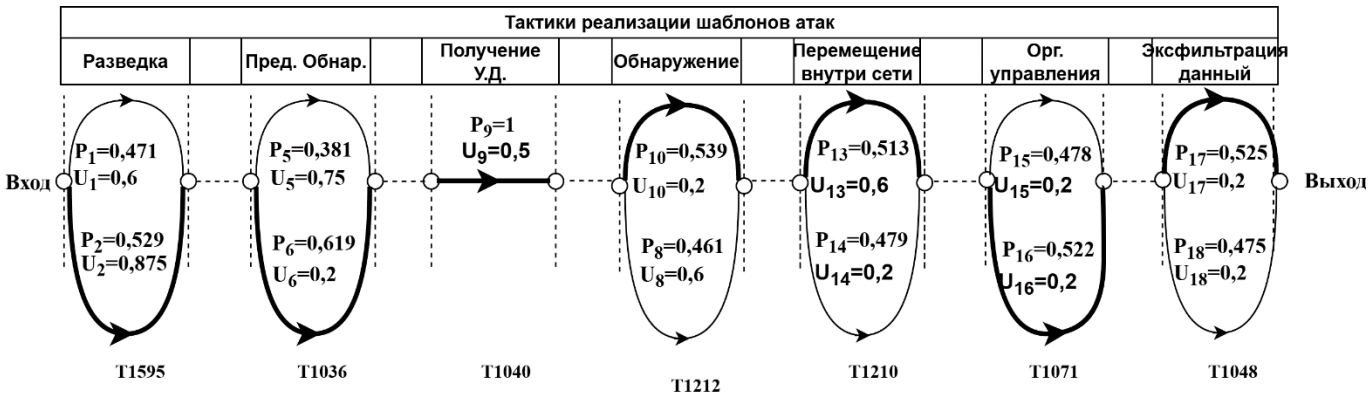


Рисунок 7 — Сценарий реализации CAPEC-287 с наибольшим показателем риска

Далее рассмотрим сценарий, изображенный на рисунке 8.



Рисунок 8 — Сценарий реализации CAPEC-287 с наименьшим показателем риска

Показатель риска данного сценария, равен:

$$Risk_{min} = ((0{,}539 * 2) * (0{,}471 * 5)) \ * \ (0{,}6 \ + \ 0{,}75 \ + \ 0{,}2 * 5) = 0{,}0158$$

Наиболее вероятным маршрутом является маршрут с наибольшим показателем риска.

Построим таблицу 38 параметров вероятных сценариев реализации шаблона кибератак CAPEC-301.

Таблица 38 – Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-301

Шаблон атаки на защищаемую систему	Техники уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-301	T1590.004	CVE-2019-0688	0,425031543	0,437475051	0,2
		CVE-2021-28442	0,546524531	0,562524949	0,2
		ИЛИ			
	T1595	CVE-2021-45486	0,433185872	0,40461313	0,5
		CVE-2021-39203	0,637431565	0,59538687	0,2
	T1205	CVE-2021-39203	0,490374005	0,316813239	0,2
		CVE-2024-11376	0,419018571	0,270713026	0,2
		CVE-2023-39326	0,638440483	0,412473735	0,2
	T1562	CVE-2024-21243	0,509466388	0,463260023	0,5
		CVE-2022-11898	0,590275359	0,536739977	0,2
	T1046 T1563	CVE-2023-35952	0,485494851	1	0,5
		CVE-2023-6332	0,813562728	0,528580969	0,5
		CVE-2021-4160	0,45833128	0,471419031	0,2
	T1210	CVE-2022-32221	0,813562728	1	0,6
		ИЛИ			
	T1565	CVE-2023-20172	0,729640708	0,561531425	0,36
		CVE-2023-38133	0,569735739	0,438468575	0,2

Наглядное визуальное и многообразия возможных альтернативных сценариев шаблона кибератаки CAPEC-301 в виде графа (рисунок 9).

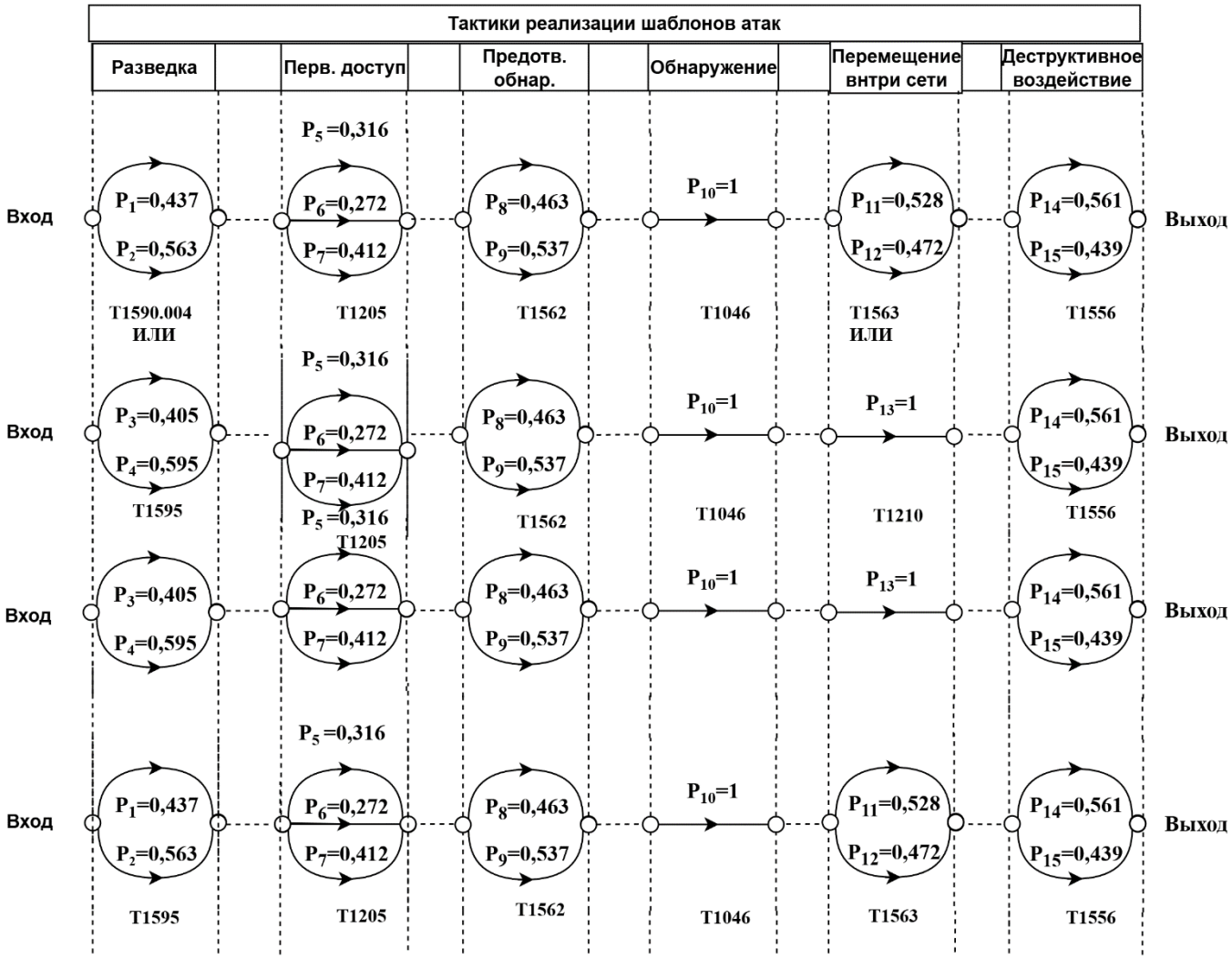


Рисунок 9 — Графовая модель вероятных сценариев реализации CAPEC-301

P_i – Вероятность успешной эксплуатации уязвимости
1 – CVE-2019-0688; 2 – CVE-2021-28442; 3 – CVE-2021-45486;
4 – CVE-2021-39203; 5 – CVE-2021-39203; 6 – CVE-2024-11376;
7 – CVE-2023-39326; 8 – CVE-2024-21243; 9 – CVE-2022-11898;
10 – CVE-2023-35952; 11 – CVE-2023-6332; 12 – CVE-2021-4160;
13 – CVE-2022-32221; 14 – CVE-2023-20172; 15 – CVE-2023-38133

Путь с наибольшим показателем риска

$$Risk_{max} = (0{,}563 * 0{,}412 * 0{,}537 * 0{,}561) * (0{,}5 + 0{,}2 + 0{,}2 + 0{,}5 + 0{,}6 + + 0{,}36) = 0{,}1649.$$

представлен на рисунке 10

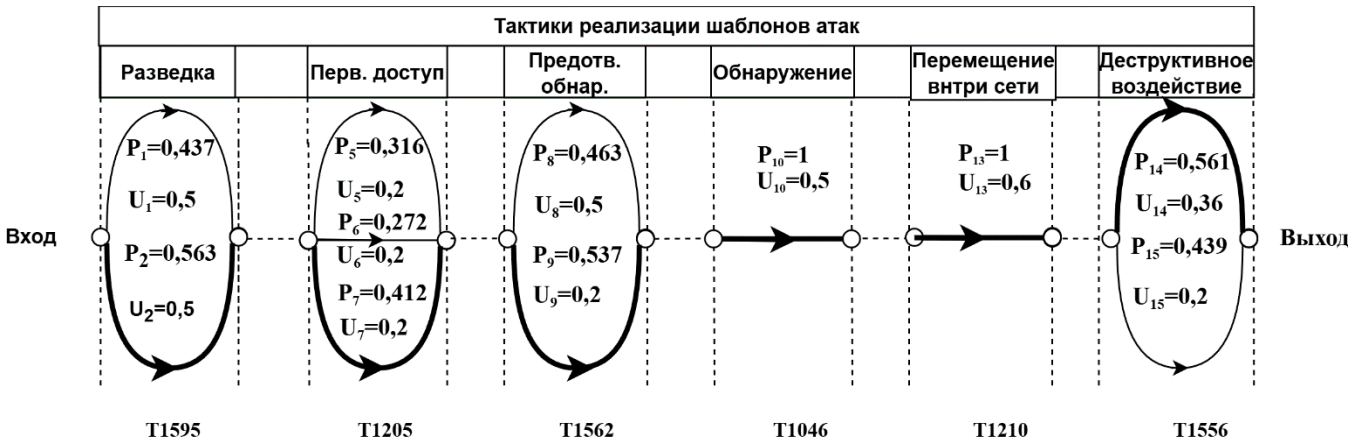


Рисунок 10 — Наиболее рисковый сценарий реализации шаблона атаки CAPEC 301

Далее рассмотрим сценарий, изображенный на рисунке 11.

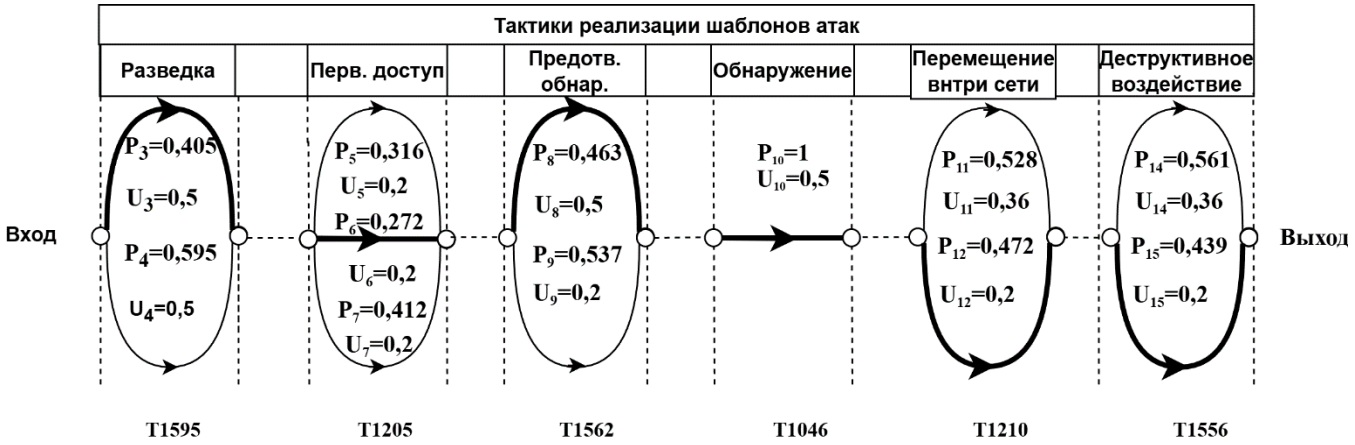


Рисунок 11 — Сценарий реализации CAPEC 301 с наименьшим показателем риска

Показатель риска данного сценария равен:

$$Risk_{min} = (0{,}405 * 0{,}272 * 0{,}463 * 0{,}472 * 0{,}439) * (0{,}5 * 4 + 0{,}2 + 0{,}2) = \\ = 0{,}0272$$

.

По данным таблицы 38 наиболее вероятным является сценарий изображенный на рисунке 12

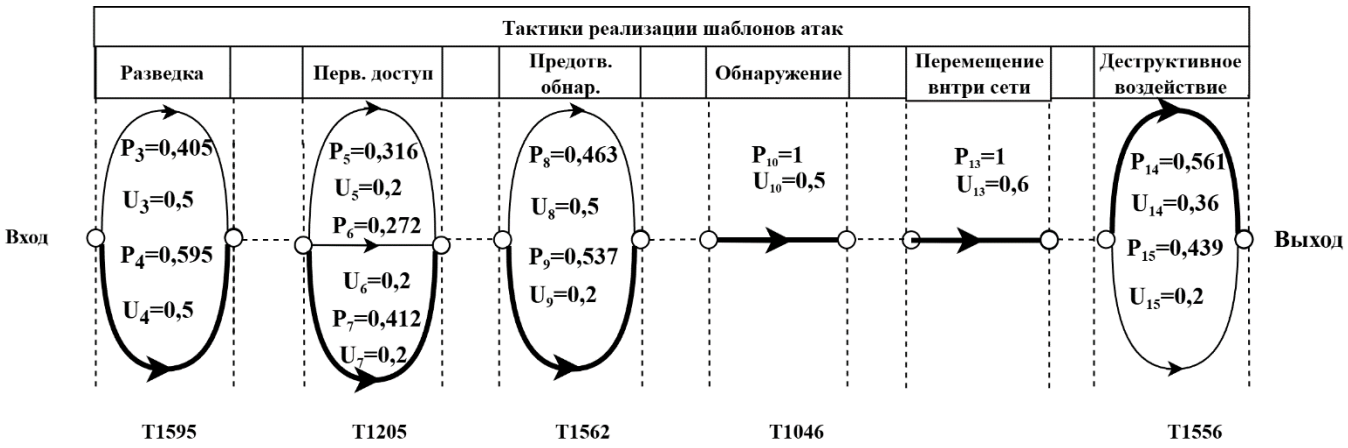


Рисунок 12 — Наиболее вероятный сценарий CAPEC-301

Теперь заполним таблицу 39 для сценариев реализации шаблона кибератак CAPEC-302.

Таблица 39 – Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-302

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы	Критичности эксплуатируемых уязвимостей	Вероятности	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-302	T1595	CVE-2024-21313	0,46198	0,323591	0,5
		CVE-2019-9824	0,475695	0,333198	0,2
		CVE-2018-5115	0,489991	0,343211	0,2
	T1133	CVE-2018-15919	0,46808	0,290176	0,2
		CVE-2019-0848	0,629274	0,390104	0,5
		CVE-2019-1108	0,515738	0,31972	0,2
	T1070	CVE-2019-0977	0,61982	0,395188	0,2
		CVE-2019-6806	0,570553	0,363777	0,2
		CVE-2020-3182	0,378044	0,241036	0,2
	T1046	CVE-2020-2889	0,613463	0,336392	0,2
		CVE-2020-3259	0,667882	0,366232	0,2
		CVE-2021-33783	0,542312	0,297376	0,2
		ИЛИ			
	T1016	CVE-2018-2587	0,482323	0,279388	0,5
		CVE-2022-29244	0,661531	0,383195	0,75
		CVE-2023-29355	0,582502	0,337417	0,75
	T1485	CVE-2025-21242	0,48022	0,482606	0,5
		CVE-2022-46698	0,514836	0,517394	0,2
		ИЛИ			
	T1499	CVE-2018-7848	0,565708	1	0,2

Далее необходимо визуализировать многообразие возможных альтернативных сценариев в виде графа (рисунок 13).

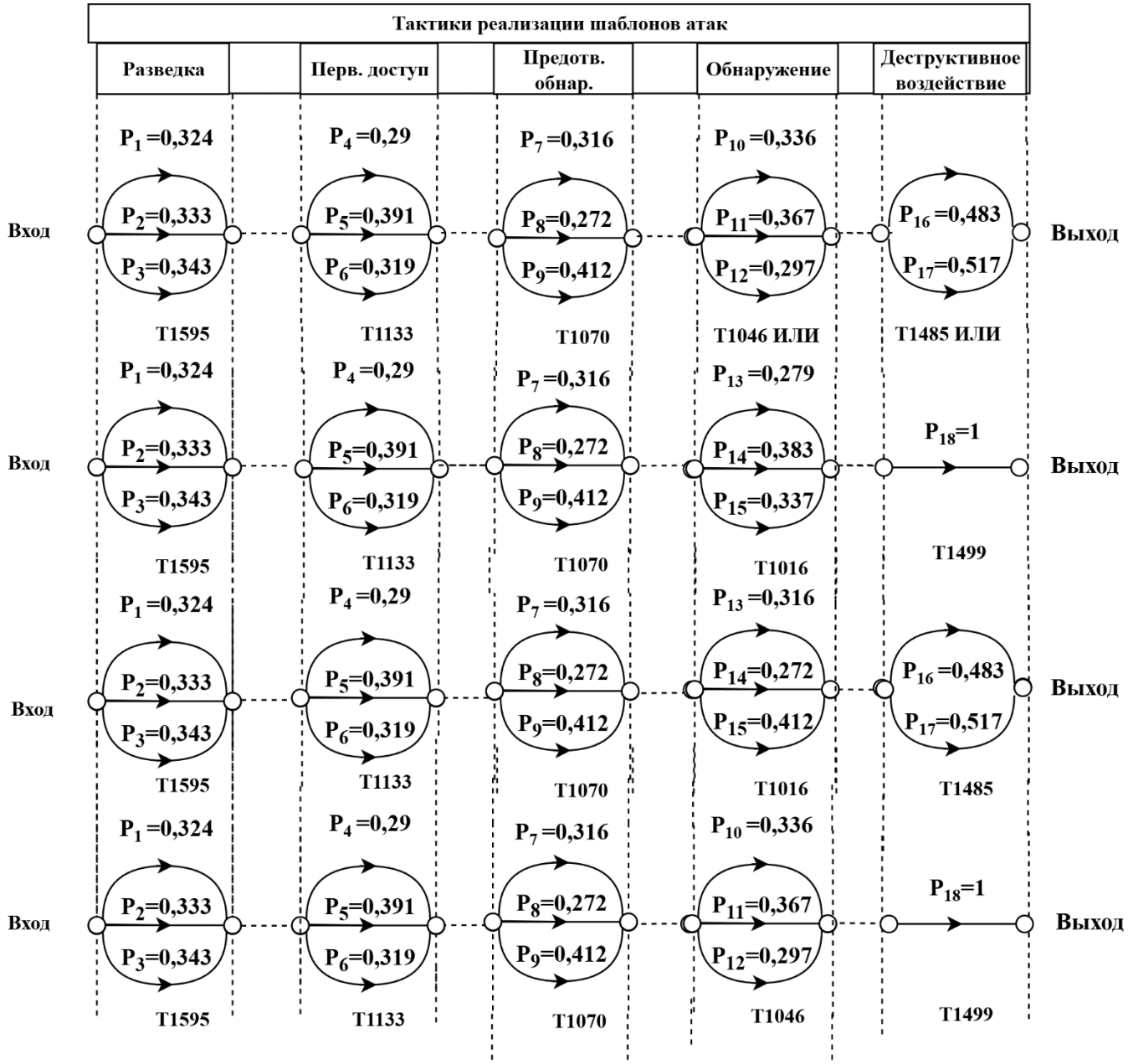


Рисунок 13 — Графовая модель вероятных сценариев реализации шаблонов CAPEC-302

P_i – Вероятность успешной эксплуатации уязвимости
1 – CVE-2024-21313; 2 – CVE-2019-9824; 3 – CVE-2018-5115;
4 – CVE-2018-15919; 5 – CVE-2019-0848; 6 – CVE-2019-1108;
7 – CVE-2019-0977; 8 – CVE-2019-6806; 9 – CVE-2020-3182;
10 – CVE-2020-2889; 11 – CVE-2020-3259; 12 – CVE-2021-33783;
13 – CVE-2018-2587; 14 – CVE-2022-29244; 15 – CVE-2023-29355;
16 – CVE-2025-21242; 17 – CVE-2022-46698; 18 – CVE-2018-7848

Наиболее рисковый сценарий указан на рисунке 14.

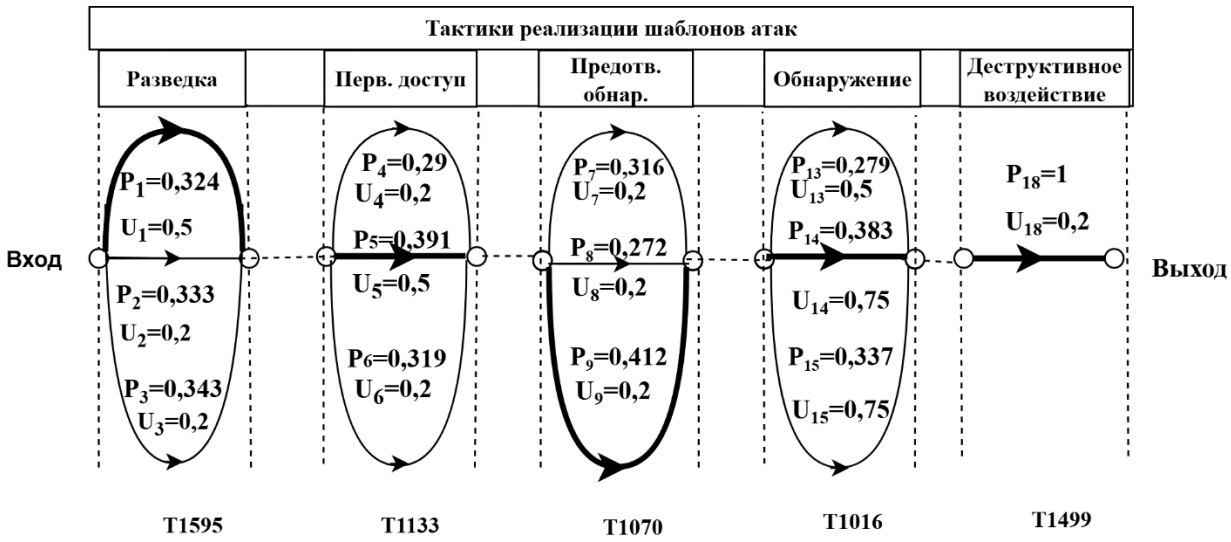


Рисунок 14 — Сценарий реализации CAPEC 302 с наибольшим показателем риска

Риск сценария равен:

$$Risk_{max} = (0{,}324 * 0{,}391 * 0{,}412 * 0{,}383) * ((0{,}5 * 2) + (0{,}2 * 2) + 0{,}75) = \\ = 0{,}0430$$

Минимальный риск сценария сценария для шаблона CAPEC 302:

$$Risk_{min} = (0{,}33 * 0{,}29 * 0{,}272 * 0{,}279 * 0{,}517) * ((0{,}2 * 4) + 0.5) = 0{,}0049$$

Визуальное представление данного сценария на рисунке 15

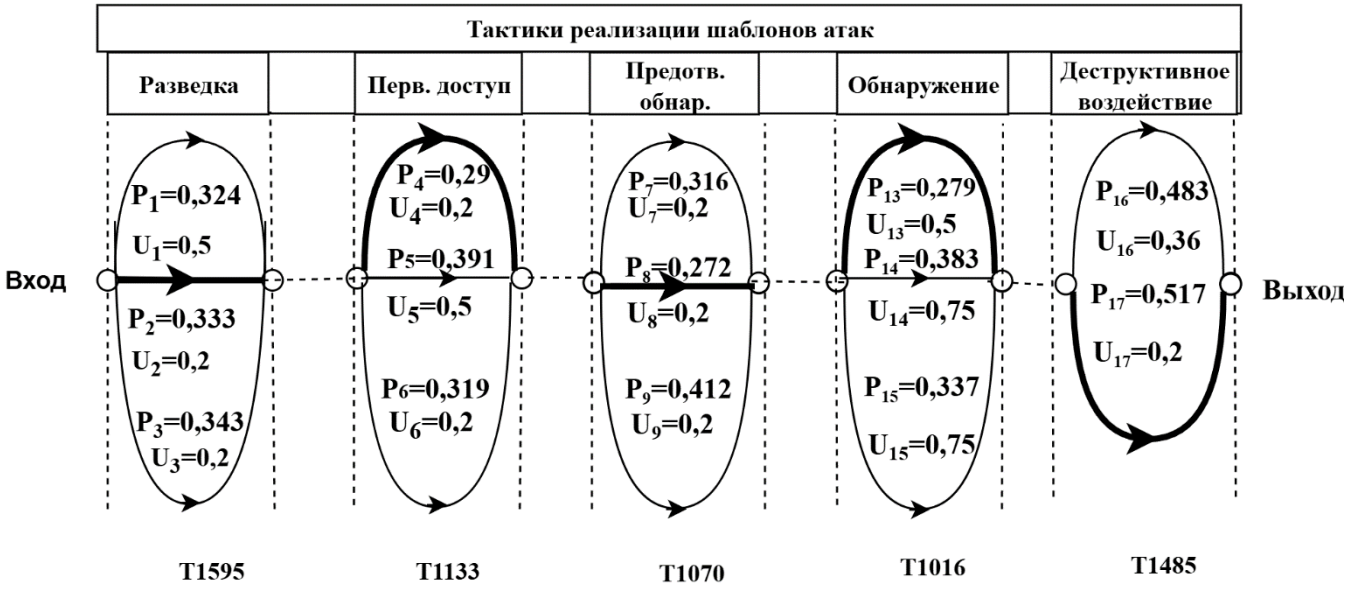


Рисунок 15 — Сценарий реализации CAPEC 302 с наибольшим показателем риска

Наиболее вероятный сценарий CAPEC-302 изображен на рисунке 16

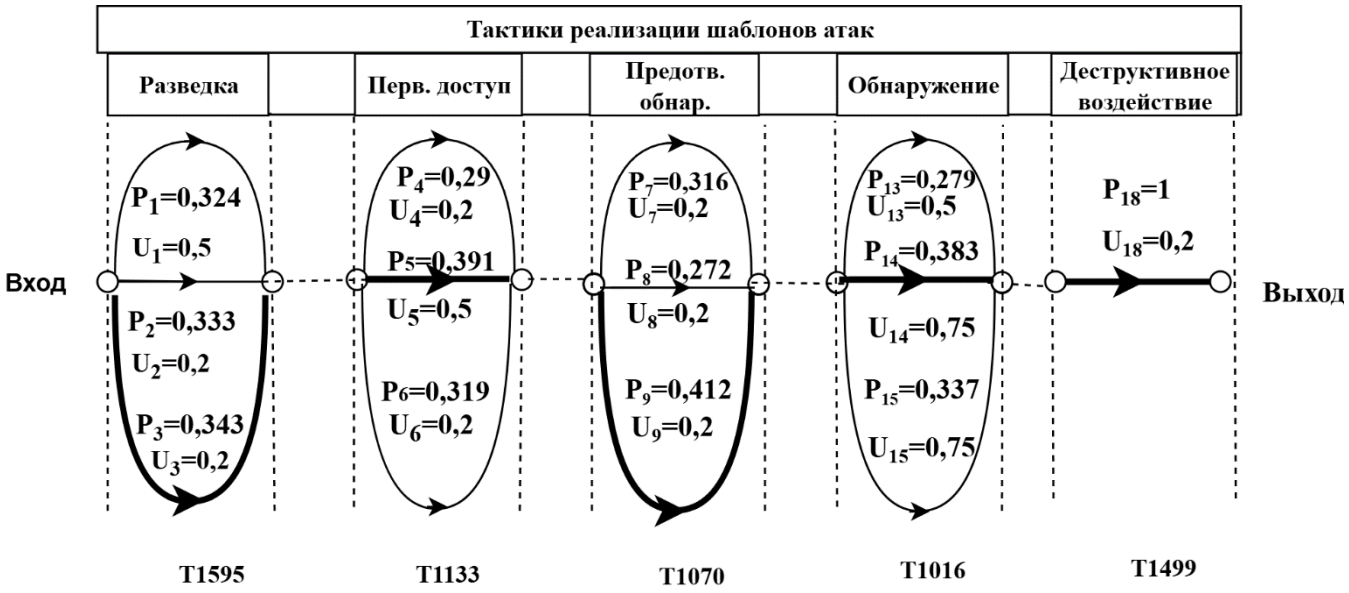


Рисунок 16 — Сценарий реализации CAPEC 302 с наименьшим показателем риска

Теперь заполним таблицу 40 для сценариев реализации шаблона кибератак CAPEC-304

Таблица 40 – Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-304

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-304	T1595	CVE-2018-5115	0,591891384	0,339919944	0,2
		CVE-2023-0027	0,535313518	0,307427589	0,5
		CVE-2023-36705	0,614062108	0,352652468	0,5
	T1133	CVE-2019-0977	0,470599684	0,260177922	0,2
		CVE-2019-0608	0,768742642	0,425010619	0,6
		CVE-2020-3182	0,569418699	0,31481146	0,2
	T1210	CVE-2022-32221	0,813562728	1	0,6
	T1016	CVE-2018-15919	0,735256275	0,569806361	0,2
		CVE-2024-21243	0,745262561	0,431445217	0,6
		ИЛИ			
	T1046	CVE-2019-0408	0,67578684	0,475554783	0,2
		CVE-2019-1108	0,555105372	0,525491081	0,2
	T048	CVE-2022-11898	0,515838551	1	0,2
		ИЛИ			
		CVE-2021-43236	0,754578865	0,652900442	0,2
	T1041	CVE-2021-34500	0,402927429	0,348099558	0,2

В результате получается наглядное визуальное и многообразия возможных альтернативных сценариев в виде графа (рисунок 17).

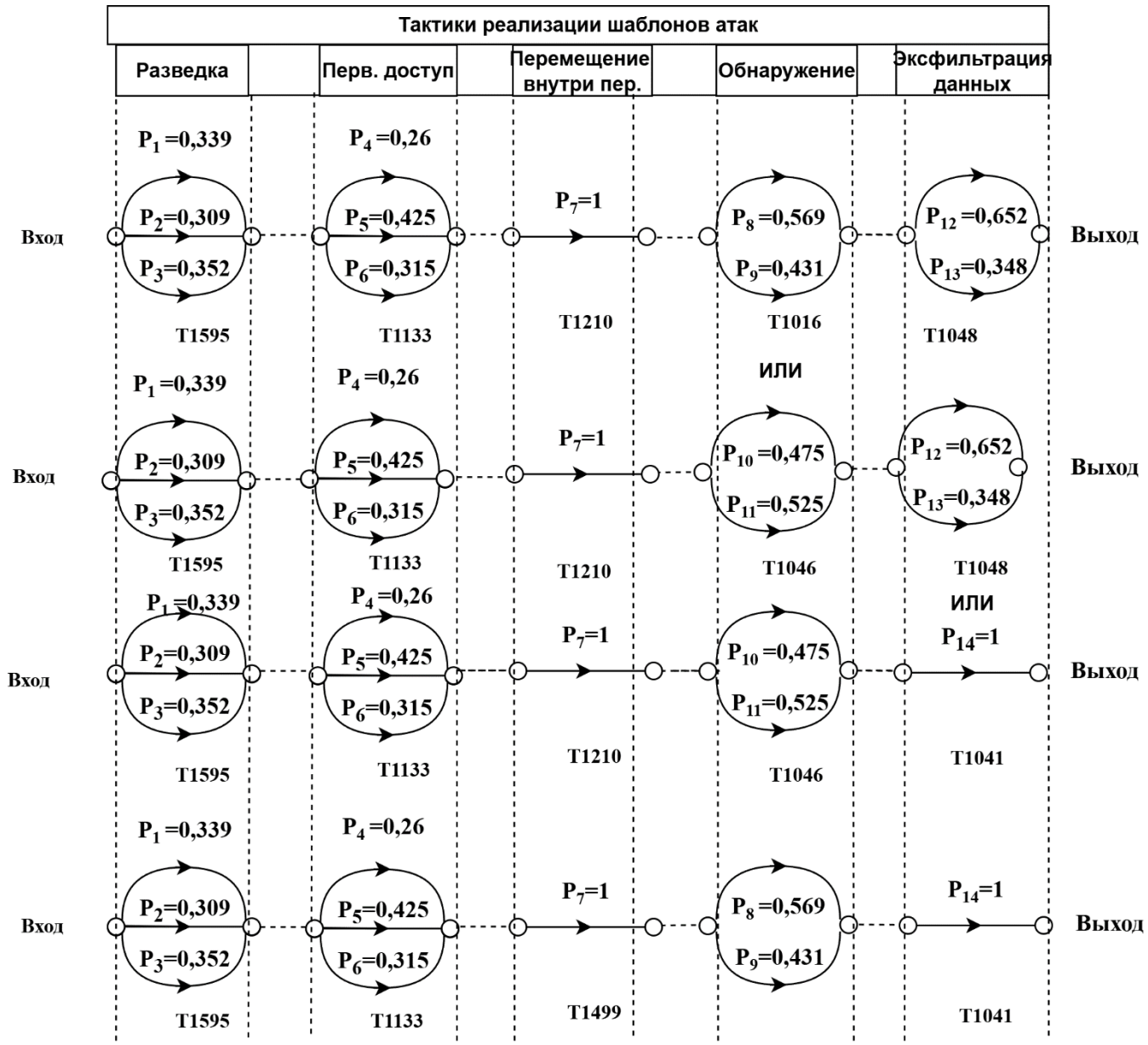


Рисунок 17 — Графовая модель вероятных сценариев реализации CAPEC-304

P_i -Вероятность успешной эксплуатации уязвимости
1 – CVE-2018-5115; 2 – CVE-2023-0027; 3 – CVE-2023-36705;
4 – CVE-2019-0977; 5 – CVE-2019-0608; 6 – CVE-2020-3182;
7 – CVE-2022-32221; 8 – CVE-2018-15919; 9 – CVE-2024-21243;
10 – CVE-2019-0408; 11 – CVE-2019-1108; 12 – CVE-2022-11898;
13 – CVE-2021-43236; 14 – CVE-2021-34500

Наибольший и наименьший риск соответственно равны:

$$Risk_{max}(0{,}352 * 0{,}425 * 0{,}569) * (0{,}6 * 3 + 0{,}5 + 0{,}2) = 0{,}2043$$

$$Risk_{min} = (0{,}339 * 0{,}26 * 1 * 0{,}431 * 0{,}348) * (0{,}2 * 3 + 0{,}5 * 2) = 0{,}0225$$

Сценарии изображены на рисунках 17 и 18.



Рисунок 17 — Сценарий реализации CAPEC 304 с наибольшим показателем риска



Рисунок 18 — Сценарий реализации CAPEC 304 с наименьшим показателем риска

Наиболее вероятный сценарий сходится с наиболее рисковым сценарием

4 Разработка организационно-правовых рекомендаций по снижению рисков для атак класса «сканирование TCP-портов»

4.1 Разработка организационных мер по снижению рисков реализации выявленных сценариев атак

Пример регламента для множества сценариев CAPEC-287 представлено в таблице 41. Остальные регламенты приведены в приложении Б

Таблица 41 – Организационно-правовые регламенты вектора атаки CAPEC-287

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Разведка	Злоумышленник отправляет частые TCP пакеты с нестандартными флагами, что свидетельствует об активном сканировании сети (T1595) с эксплуатацией CVE-2022-1012, CVE-2020-11898.	1.Проанализировать логи межсетевого экрана на аномальный всплеск незаконченных TCP соединений. 2. Собрать сетевой дамп для последующего расследования инцидента. 3. Заблокировать несанкционированные IP-адреса, генерирующие нестандартные TCP-пакеты.	1. Установить патчи для CVE-2022-1012 и CVE-2020-11898. 2. Сегментировать сеть с помощью добавления автономии между VLAN 3.После исследования. сетевого дампа ужесточить правила для входящего трафика на пограничных устройствах сетевой безопасности. 4. Обеспечить важные сетевые сервисы туннелированием.
Предотвращение обнаружения	Хеши исполняемых файлов не совпадают с хешем исходных, что свидетельствует о реализации техники (1562.004) (CVE-2020-12802, CVE-2020-2584).	1. Использовать системные журналы для нахождения изменённых или переименованных файлов. 2.Обновить IDS, добавив новые сигнатуры. 3.Использовать бэкапы для восстановления изначального состояния рабочего скрипта.	1. Внедрить контроль целостности файлов для системных папок 2. Ограничить запуски несанкционированных скриптов из неподтвержденных директорий. 3. Обновить программное обеспечение для закрытия слабых мест, которые можно реализовать с помощью уязвимостей.

Продолжение таблицы 41

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Предотвращение обнаружения	Маскировка эксплойтов под легитимные файлы сигнализирует о маскировке процессов и изменении артефактов (CVE-2021-3449, CVE-2021-34749).	1. Воспользоваться системными журналами для поиска измененных или переименованных файлов. 2. Обновить IDS, дополнив новые сигнатуры. 3. Использовать бэкапы для восстановления первоначального положения рабочего скрипта.	1. Ввести контроль полноты файлов для системных папок. 2. Предотвратить запуски несанкционированных скриптов из недостоверных директорий. 3. Обновить программное обеспечение для закрытия уязвимых мест, которые можно реализовать с помощью уязвимостей.
Получение учётных данных	Аномальные GET/POST в которых передаются учетные данные сигнализируют о возможном применении (T1040) с присущими ей уязвимостями.	1. С помощью логов проанализировать вызовы API для сетевого сниффига. 2.Отозвать скомпрометированные токены аутентификации.	1. Установить патчи для CVE-2024-21243 и т. д. 2.Принудительно отозвать все пароли. 3. Организовать многофакторную аутентификацию для повышения уровня.
Получение учётных данных	Фиксируется аномальное повышение активности специализированных POST запросов, что сигнализирует о возможном применении техники (T1212) с помощью CVE-2022-30556, CVE-2022-39282.	1. Сохранить сетевой POST запрос: tcpdump -n -i eth0 'port 80 or port 443' -w web_creds.pcap 2. Завершить сетевые процессы использующие специализированные пост устройства.	1. Организовать обновление серверных компонентов для закрытия уязвимостей CVE-2022-30556, CVE-2022-39282. 2. Сбросить сертификаты для предотвращения дальнейшей компрометации узлов. 3.Пересмотреть политику системы в отношении вводимых данных.

Продолжение таблицы 41

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Обнаружение	Фиксируется смена режима сетевого порта при которой принимаются все пакеты в сети, что может сигнализировать о применении техники (T1040) с помощью уязвимостей	1. Отключить неразборчивый режим: ip link set eth0 promisc off. 2. Запустить мониторинг новых MAC-адресов. 3. Отключить зеркальные порты на коммутаторе	1. Установить патчи для закрытия уязвимости CVE-2020-25718. 2. Восстановить образов из бэкапов. 3. Сменить все скомпрометированные токены и пароли
Перемещение внутри периметра	Фиксируется смена режима сетевого порта при которой принимаются все пакеты в сети, что может сигнализировать о применении техники (T1040) с помощью уязвимостей.	1. Отключить неразборчивый режим: ip link set eth0 promisc off. 2. Запустить мониторинг новых MAC-адресов. 3. Отключить зеркальные порты на коммутаторе.	1. Установить патчи для закрытия уязвимости CVE-2020-25718. 2. Восстановить образов из бэкапов. 3. Сменить все скомпрометированные токены и пароли.
Экфильтрация данных	С помощью логов фиксируется подключения из нетипичных сегментов, что сигнализирует о возможном применении тактики (T1210) с помощью CVE-2023-33952, CVE-2024-0753.	1. Проанализировать логи SSH на возможные подключения из нетипичных хостов: journalctl -u ssh -S "1 week ago 2.Заблокировать злоумышленниказ-лоумышленика. 3.Изолировать узел в межсетевом экране.	1. Установить патчи для SSH/RDP, чтобы закрыть CVE-2023-33952, CVE-2024-0753. 2. Активировать многофакторную аутентификацию для каждого удаленного соединения. 3. Переформировать доверительные списки.

ЗАКЛЮЧЕНИЕ

В ходе проведенного исследования была достигнута поставленная цель — повышение защищенности автоматизированных информационных сетей посредством развития методического обеспечения риск-анализа кибератак класса «Сканирование TCP-портов», благодаря полученным в ходе исследований следующим результатам:

– структурированная база данных кибератак класса «Сканирование TCP-портов» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– выработана методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Сканирование TCP-портов», с учётом специфики используемых злоумышленников сценариев;

– сформирован комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Сканирование TCP-портов» на уязвимости АИС.

Полученные результаты подтверждают достижение цели исследования, заключающейся в повышении защищённости автоматизированных сетей от комплексных атак класса «Сканирование TCP-портов».

Предложенный метод позволил создать обоснованное представление о рисках в АИС, связанных с успешным обнаружением слабых мест в системе при применении «Сканирования TCP-портов». Проведенная оценка указывает наиболее подверженные угрозам места в системе.

Внедрение предложенных мер, связанных с кибератаками класса «Сканирование TCP-портов», может существенно снизить риск успешной эксплуатации уязвимостей в автоматизированных информационных системах. Сформированные подходы к оценке рисков и их управлению формируют надежный фундамент для организации комплексной защиты системы от атак класса «Сканирование TCP-портов».

Представленное исследование подтверждает необходимость глубокой проработки вопросов, касающихся рисков успешной реализации атак типа «Сканирование

TCP-портов». Разработанная методология позволяет качественно улучшать безопасность корпоративных сетей, минимизировать риски и повышать общую устойчивость организаций к внешним угрозам.

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1. – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2. – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3. – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4. – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5. – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6. – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7. – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8. – Текст: непосредственный.

9 Актуальные киберугрозы. – Электрон. Дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/. – Текст: электронный. – Текст: непосредственный.

10 Компания Have You seen me опубликовала отчёт . – Электрон. дан. – Режим доступа: https://dl.acm.org/doi/10.1145/3646547.3688409 – Текст: электронный.

11 Аналитический отчет о реагировании на инциденты в 2024 году – Электрон. дан. – Режим доступа: https://securelist.ru/kaspersky-incident-response-report 2024/112080/. – Текст: электронный.

12 Ландшафт вредоносных атак: аналитика с сенсоров и ханипотов – Электрон. дан. – Режим доступа: https://rtsolar.ru/upload/iblock/9ee/trkzgewrs87olv3xzl2b8g83sfuguqsw/Analytics_from_sensors_ and_honeypotsQ4vQ1.pdf. – Текст: электронный.

13 CAPEC. – Электрон. Дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

14 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

15 PT Security MITRE. – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

16 MITRE EMB3D. – Электрон. дан. – Режим доступа: https://emb3d.mitre.org/. – Текст: электронный.

17 ATLAS MITRE. – Электрон. дан. – Режим доступа: https://atlas.mitre.org/. – Текст: электронный.

18 ATLAS SecurityHub. – Электрон. дан. – Режим доступа: https://atlas.securityhub.ru/. – Текст: электронный.

19 База данных угроз ФСТЭК (BDU). – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

20 Центр безопасности данных. – Электрон. Дан. – Режим доступа: https://data-sec.ru/personal-data/threats-data-bank. – Текст: электронный.

21 Национальный координационный центр по компьютерным инцидентам. – Электрон. дан. – Режим доступа: https://cert.gov.ru/. – Текст: электронный.

22 NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

23 CVE. – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

24 CVSS. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/. – Текст: электронный.

25 CVSS v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3-1/. – Текст: электронный.

26 CVSS v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4-0/. – Текст: электронный.

27 EPSS. – Электрон. дан. – Режим доступа: https://www.first.org/epss. – Текст: электронный.

28 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp-risk-rating.com/. – Текст: электронный.

29 CISA SSVC Calculator. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

30 VISS CVSS Calculator. – Электрон. дан. – Режим доступа: https://viss.zoom.com/calculator/. – Текст: электронный.

31 Остапенко, А. А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А. А. Остапенко // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 543-552. – Текст: непосредственный.

32 Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А. А. Остапенко, В. П. Шелякин, Е. С. Короткова [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 521-542. – Текст: непосредственный.

33 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

34 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

35 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

36 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

37 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный.

38 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4.- С.597-602. – Текст: непосредственный.

39 Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 235-246.

40 Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин

// Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598. – Текст: непосредственный.

41 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 231-238. – Текст: непосредственный.

42 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный.

43 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 219-230.

44 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 7-30.

45 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 261-276.

46 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54.

47 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336.

48 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378.

49 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400.

50 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420.

51 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106.

52 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 115-128.

53 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484.

54 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284.

55 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. № 2. С. 285-298.

56 Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 2. – С. 219-230. – Текст: непосредственный.

57 Формализация знаний и данных кибератак и уязвимостей / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 2. – С. 231-238. – Текст: непосредственный.

58 ГОСТ Р ИСО/МЭК 15408-2-2013 Методы и средства обеспечения безопасности. критерии оценки безопасности информационных технологий – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200105710– Текст: электронный.

59 ГОСТ Р ИСО/МЭК 27001-2021 Информационная технология (ИТ). Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. – Электрон. дан. – Режим доступа: https://gostassistent.ru/doc/ec4dfe5d-a428-4404-8613-32edc5826be9– Текст: электронный.

60 ГОСТ Р 59710-2022. Защита информации. Управление компьютерными инцидентами. Общие положения. – Электрон. дан. – https://docs.cntd.ru/document/12001094356. Режим доступа:– Текст: электронный.

61 ГОСТ Р 59711-2022. Защита информации. Управление компьютерными инцидентами. Организация деятельности по реагированию на компьютерные инциденты. – Электрон. дан. – https://internet-law.ru/gosts/gost/76267/. Режим доступа: – Текст: электронный.

62 Стандарт ГОСТ Р 59547-2021 Защита информации. Мониторинг информационной безопасности. Общие положения – Электрон. дан. – https://docs.cntd.ru/document/12001094394. Режим доступа: – Текст: электронный

63 ИСО/МЭК 13335-1:2006 Информационная технология. Методы и средства обеспечения безопасности. Часть 1. Концепция и модели менеджмента безопасности информационных и телекоммуникационных технологий Электрон. дан. – https://protect.gost.ru/document.aspx?control=8&id=120843. Режим доступа: – Текст: электронный:

ПРИЛОЖЕНИЕ А

Таблица А1 – Паспорт уязвимости CVE-2022-1012

Идентификатор уязвимости	CVE-2022-1012 Уязвимость TCP-портов ядра операционной системы Linux связана с раскрытием генерации номеров. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, предугадать номер порта исходящего TCP-соединения
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А2 – Паспорт уязвимости CVE-2023-45236

Идентификатор уязвимости	CVE-2023-45236 Сервис обработки начального номера последовательности TCP уязвим к переполнению буфера. Использование этой уязвимости даёт злоумышленнику, действующему дистанционно, возможность несанкционированного доступа к конфиденциальной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3,3)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А3 – Паспорт уязвимости CVE-2018-15473

Идентификатор уязвимости	CVE-2018-15473 Сервер обрабатывает как запросы на аутентификацию как существующих, так и для несуществующих учетных записей. Злоумышленник может воспользоваться этой особенностью и с помощью специально сформированных запросов аутентификации раскрыть защищаемые данные сервера
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена в ходе исследований
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А4 – Паспорт уязвимости CVE-2020-17133

Идентификатор уязвимости	CVE-2020-17133 В Системе управления предприятием Dynamics NAV не предусмотрены алгоритмы защиты данных аутентификации . Использование бреши в системе управления предприятием даёт злоумышленнику на расстоянии, возможность получить доступ к охраняемым данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А5 – Паспорт уязвимости CVE-2023-36905

Идентификатор уязвимости	CVE-2023-36905 WwanSvc не имеет алгоритмов защиты служебных данных, что может быть использовано как уязвимость. Эксплуатация уязвимости может позволить нарушителю раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А6 – Паспорт уязвимости CVE-2024-21183

Идентификатор уязвимости	CVE-2024-21183 Сервер имеет уязвимость в ядре приложения Oracle, которая связанна с отстутствием протоколов защиты данных аутентификации. Эксплуатация слабого места способна дать возможность злоумышленнику, находящемуся на удалённом расстоянии, обрести неправомерный доступ к охраняемым данным, задействуя сетевые протоколы.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А7 – Паспорт уязвимости CVE-2018-8444

Идентификатор уязвимости	CVE-2018-8444 Сетевой протокол, который обеспечивает логирование событий на сервере (SMBv2), имеет уязвимость, связанную с ошибками при обработке входных данных. Использование уязвимости потенциально позволяет злоумышленнику, находящемуся вне сети, получить доступ к конфиденциальным данным, отправляя специально сконструированные SMBv2 запросы.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:L
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,6)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А8 – Паспорт уязвимости CVE-2022-38026

Идентификатор уязвимости	CVE-2022-38026 У DHCP-клиента операционной системы Windows отсутствуют протоколы защиты сетевых данных системы. Используя уязвимость, удаленно, можно получить несанкционированный доступ к системе
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А9 – Паспорт уязвимости CVE-2021-40454

Идентификатор уязвимости	CVE-2021-40454 Компонент Rich Text Edit Control в Windows содержит уязвимость, связанная с раскрытием данных. При её эксплуатации удалённый злоумышленник может получить несанкционированный доступ к охраняемой информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А10 – Паспорт уязвимости CVE-2022-39283

Идентификатор уязвимости	CVE-2022-39283 При обработке параметра `/video` RDP-клиент FreeRDP выходит за пределы выделенного буфера памяти, что создает уязвимость. При её использовании удалённый злоумышленник получает возможность читать, модифицировать или удалять аудио- и видеоданные.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А11 – Паспорт уязвимости CVE-2024-29960

Идентификатор уязвимости	CVE-2024-29960 В сервере Brocade SANnav до v2.3.1 и v2.3.0a ключи SSH внутри образа OVA идентичны в виртуальной машине каждый раз, когда устанавливается SANnav. Любая виртуальная машина Brocade SAnnav, основанная на официальных образах OVA, уязвима для MITM через SSH. Злоумышленник может расшифровать и скомпрометировать трафик SSH к SANnav.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,7)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А12 – Паспорт уязвимости CVE-2024-39884

Идентификатор уязвимости	CVE-2024-39884 Регрессия в ядре Apache HTTP Server 2.4.60 игнорирует часть использования устаревшей конфигурации обработчиков на основе типа контента. "AddType" и подобная конфигурация при некоторых обстоятельствах, когда файлы запрашиваются косвенно, приводят к раскрытию исходного кода локального контента
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А13 – Паспорт уязвимости CVE-2021-28328

Идентификатор уязвимости	CVE-2021-28328 Служба доменных имен системы имеет слабость в обработке служебных данных. Эксплуатация этой слабости может позволить злоумышленнику, получить возможный доступ к системе
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А14 – Паспорт уязвимости CVE-2023-32037

Идентификатор уязвимости	CVE-2023-32037 Уязвимость Windows связаная с сетевым мостом второго уровня может привести к раскрытию данных о системе. При её эксплуатации удалённый злоумышленник может получить несанкционированный доступ к охраняемой информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,1)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А15 – Паспорт уязвимости CVE-2022-30134

Идентификатор уязвимости	CVE-2022-30134 Операционная система имеет уязвимость в Microsoft Exchange Server связаную с недостаточной защитой отправляемых сообщений электронной почты. Злоумышленник, успешно воспользовавшийся уязвимостью, мог прочитать целевые сообщения электронной почты.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А16 – Паспорт уязвимости CVE-2024-43609

Идентификатор уязвимости	CVE-2024-43609 Уязвимость Apps for Enterprise связана отсутствием проверки достоверности получаемой информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, проводить спуфинг-атаки
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А17 – Паспорт уязвимости CVE-2023-36052

Идентификатор уязвимости	CVE-2023-36052 Уязвимость раскрытия информации при использовании команд REST в Azure. Эксплуатация слабости может позволить нарушителю, действующему удаленно, получить доступ к учетным данным
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А18 – Паспорт уязвимости CVE-2024-42256

Идентификатор уязвимости	CVE-2024-42256 В ядре Linux существует уязвимость уязвимость функции smb2_async_writev() Эксплуатация уязвимости связана с некорректным управлением ресурсом в результате повторного выбора сервера при повторной попытке подзапроса.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А19 – Паспорт уязвимости CVE-2021-25122

Идентификатор уязвимости	CVE-2021-25122 В Apache Tomcat при обработке запросов по протоколу HTTP/2 отсутствуют механизмы защиты служебных данных, что может быть использовано удалённым злоумышленником для нарушения конфиденциальности, целостности и доступности информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А20 – Паспорт уязвимости CVE-2018-93401

Идентификатор уязвимости	CVE-2018-93401 Уязвимость рандомизированной генерации номеров исходящих TCP-портов ядра операционной системы Linux связана с раскрытием информации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, предугадать номер порта исходящего TCP-соединения
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5.8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 6.3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А21 – Паспорт уязвимости CVE-2021-28442

Идентификатор уязвимости	CVE-2021-28442 В реализации TCP/IP стека в Microsoft Windows отсутствуют протоколы защиты служебных данных, что при использовании уязвимости позволяет удалённому злоумышленнику получить несанкционированный доступ к конфиденциальной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А22 – Паспорт уязвимости CVE-2023-36438

Идентификатор уязвимости	CVE-2023-36438 В стеке TCP/IP существует уязвимость связанная с слабыми мерами по защите передаваемых данных. Злоумышленник воспользовавшись уязвимостью может получить несанкционированный доступ к передаваемой конфиденциальной информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А23 – Паспорт уязвимости CVE-2023-41749

Идентификатор уязвимости	CVE-2023-41749 Раскрытие конфиденциальной информации из-за чрезмерного сбора системной информации. Затронутыми являются следующие продукты: Acronis Agent (Windows) до сборки 32047, Acronis Cyber Protect 15 (Windows) до сборки 35979.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А24 – Паспорт уязвимости CVE-2021-4160

Идентификатор уязвимости	CVE-2021-4160 В процедуре возведения в квадрат MIPS32 и MIPS64 есть уязвимость распространения переноса. Затрагиваются многие алгоритмы протокола , включая некоторые кривые по умолчанию TLS 1.3. Злоумышленник может воспользоваться данной слабостью, что бы повысить уровень доступа в системе
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А25 – Паспорт уязвимости CVE-2022-32221

Идентификатор уязвимости	CVE-2022-32221 При передаче по HTTP(S) libcurl существует уязвимость обратного вызова чтения(`CURLOPT_READFUNCTION`), которая для запроса данных для отправки, даже если установлена опция `CURLOPT_POSTFIELDS`, если тот же дескриптор ранее использовался для выдачи запроса `PUT`, который использовал этот обратный вызов.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А26 – Паспорт уязвимости CVE-2023-21741

Идентификатор уязвимости	CVE-2023-21741 В Microsoft Visio, равно как и в пакетах Microsoft Office и 365 Apps for Enterprise, наблюдается недостаточная защита служебных данных, что является фактором риска. Использование данной уязвимости предоставляет возможность удалённому злоумышленнику получить несанкционированный доступ к секретной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5)
	Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А27 – Паспорт уязвимости CVE-2023-38133

Идентификатор уязвимости	CVE-2023-38133 В модуле, отвечающем за рендеринг веб-страниц в Safari, обнаружена потенциальная угроза утечки данных. Использование этой уязвимости может дать возможность злоумышленнику, находящемуся на удаленном расстоянии, осуществить несанкционированное получение доступа к данным, находящимся под защитой.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А28 – Паспорт уязвимости CVE-2020-11898

Идентификатор уязвимости	CVE-2020-11898 В стеке протоколов Treck TCP/IP, используемом для IPv4/ICMPv4, выявлена уязвимость. Она представляет собой утечку информации, что может быть использовано для получения несанкционированного доступа к данным. Удалённый злоумышленник, воспользовавшись этой уязвимостью, получает возможность компрометировать конфиденциальные сведения.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9,4)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А29 – Паспорт уязвимости CVE-2022-36074

Идентификатор уязвимости	CVE-2022-36074 В серверном компоненте не реализованы механизмы защиты служебных данных. Это создаёт уязвимость, при которой удалённый злоумышленник может через сетевое взаимодействие получить несанкционированный доступ к конфиденциальной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 6,9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А30 – Паспорт уязвимости CVE-2024-21313

Идентификатор уязвимости	CVE-2024-21313 Уязвимость в реализации TCP протокола в операционных системах Windows проистекает из дефектов механизма контроля доступа. Использование этой уязвимости может дать злоумышленнику, находящемуся удаленно, возможность получить доступ к конфиденциальной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А31 – Паспорт уязвимости CVE-2019-1108

Идентификатор уязвимости	CVE-2019-1108 Уязвимость раскрытия информации возникает, когда клиент Windows RDP ненадлежащим образом раскрывает содержимое своей памяти, также известная как «Уязвимость раскрытия информации клиента протокола удаленного рабочего стола».
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А32 – Паспорт уязвимости CVE-2020-3259

Идентификатор уязвимости	CVE-2020-3259 Уязвимость веб-интерфейса микропрограммного обеспечения межсетевых экранов Cisco Adaptive Security Appliance (ASA) и Configure Firepower Threat Defense (FTD) связана с ошибками обработки объектов в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А33 – Паспорт уязвимости CVE-2018-2587

Идентификатор уязвимости	CVE-2018-2587 Сложная эксплуатация уязвимости позволяет неаутентифицированному злоумышленнику с сетевым доступом через HTTP скомпрометировать Oracle Access Manager. Успешные атаки на эту уязвимость могут привести к несанкционированному созданию, удалению или изменению доступа к критически важным данным или всем доступным данным Oracle Access Manager, а также к несанкционированному доступу на чтение к подмножеству доступных данных Oracle Access
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А34 – Паспорт уязвимости CVE-2022-29244

Идентификатор уязвимости	CVE-2022-29244 Пакетный менеджер npm имеет слабость раскрытия . Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А35 – Паспорт уязвимости CVE-2023-29355

Идентификатор уязвимости	CVE-2023-29355 Сетевой протокол DHCP Windows имеет уязвимость, связанную с раскрытием данных о сетевой топологии. Эксплуатация бреши в протоколе может потенциально дать возможность злоумышленнику, находящемуся вне зоны доступа, получить доступ к охраняемым данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А36 – Паспорт уязвимости CVE-2025-21242

Идентификатор уязвимости	CVE-2025-21242 Протокол Kerberos недостаточно защищает важные системные данные, что является уязвимостью, которую злоумышленник может реализовать. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А37 – Паспорт уязвимости CVE-2022-46698

Идентификатор уязвимости	CVE-2022-46698 Уязвимость WebKitGTK, может привести к раскрытию данных веб- сервисов. Воспользовавшись этой брешью в системе, злоумышленник, находящийся на удаленном расстоянии, может получить несанкционированный доступ к конфиденциальным данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А38 – Паспорт уязвимости CVE-2018-7848

Идентификатор уязвимости	CVE-2018-7848 Уязвимость сетевого протокола связана с утечкой информации. Использование данной уязвимости предоставляет злоумышленнику, имеющему удаленный доступ, возможность получить серверные данные при чтении файлов с контроллера.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Организационные меры
Участие в инцидентах	Нет

Таблица А39 – Паспорт уязвимости CVE-2023-36706

Идентификатор уязвимости	CVE-2023-36706 Служба развертывания ОС имеет слабость в связи с отсутствием защиты критически важных данных. Уязвимость может быть реализована удаленно и привести к раскрытию важных системных данных
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А40 – Паспорт уязвимости CVE-2018-20445

Идентификатор уязвимости	CVE-2018-20445 D-Link DCM-604 и DCM-704 неправильно обрабатывает запросы сетевого сервиса. Уязвимости в DCM-604 может позволить преступнику, раскрыть данные аутентификации пользователей
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)\
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А41– Паспорт уязвимости CVE-2017-7484

Идентификатор уязвимости	CVE-2017-7484 Уязвимость в системе управления базами данных возникает из-за недостаточной проверки прав доступа пользователя перед тем, как предоставить информацию из таблицы pg_statistic. Преступник осуществляющий атаку удалённо, может привести к получению доступа к конфиденциальной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А42 – Паспорт уязвимости CVE-2020-1744

Идентификатор уязвимости	CVE-2020-1744 В Keycloak обнаружена уязвимость, затрагивающая систему управления идентификацией и доступом. Удаленный злоумышленник, потенциально, способен эксплуатировать эту брешь, чтобы получить несанкционированный доступ к конфиденциальным данным, подверженным защите.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А43 – Паспорт уязвимости CVE-2021-34500

Идентификатор уязвимости	CVE-2021-34500 Ядро Windows имеет слабость, которая может быть связанна с раскрытием информации. Эксплуатация слабости в защите потенциально открывает возможность для удаленного злоумышленника обрести несанкционированный доступ к конфиденциальным данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А44 – Паспорт уязвимости CVE-2021-43236

Идентификатор уязвимости	CVE-2021-43236 Операционная система Windows имеет слабость сетевого протокола связаная с раскрытием информации. Злоупотребление этой уязвимостью может предоставить удалённому нарушителю несанкционированный доступ к охраняемым данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А45 – Паспорт уязвимости CVE-2021-28324

Идентификатор уязвимости	CVE-2021-28324 Уязвимость использования (SMB) в операционных системах связана с ошибками обработки объектов в памяти. Использование уязвимости потенциально даёт возможность злоумышленнику, действующему дистанционно, добиться несанкционированного доступа к конфиденциальной информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А46 – Паспорт уязвимости CVE-2021-28325

Идентификатор уязвимости	CVE-2021-28325 Уязвимость реализации сетевого сервиса Windows. Использование данной уязвимости способна предоставить злоумышленнику, действующему дистанционно, возможность неправомерного получения доступа к охраняемым данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А47 – Паспорт уязвимости CVE-2020-17140

Идентификатор уязвимости	CVE-2020-17140 Уязвимость раскрытия информации Windows SMB
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А48 – Паспорт уязвимости CVE-2023-28175

Идентификатор уязвимости	CVE-2023-28175 Уязвимость SSH с недостаточной защитой с данных. Использование этой уязвимости способно предоставить злоумышленнику, осуществляющему атаку удаленно, возможность несанкционированного доступа к сети, посредством отправки запроса на переадресацию портов.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,6)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

ПРИЛОЖЕНИЕ Б

Таблица – Б1 Организационно-правовые регламенты вектора атаки CAPEC-303

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на Регистрируемые инциденты	Меры ликвидации последствий инцидентов
Разведка	На этапе Разведки происходит частое сетевое сканирование сигнализирует о применении техники (T1595), с возможным эксплуатированием уязвимостей CVE-2022-1012; CVE-2023-45236; CVE-2018-15473.	1. При появлении аномальной активности необходимо блокировать все подозрительные пакеты с помощью межсетевого экрана и ограничить скорость новых соединений; 2. Настроить оповещения на аномально высокие объемы пакетов со всеми установленными флагами; 3.Настроить сигнатуры на обнаружение Xmas сканирования.	1.Установить официальные патчи, с целью закрыть CVE-2022-1012; CVE-2023-45236; CVE-2018-15473; 2.Сегментировать сеть для ограничения доступа к ним с пограничных хостов; 3.Ужесточить политику списков доступа на пограничных экранах.
Первоначальный доступ	При реализации техники (T1199) злоумышленник пытается эксплуатировать CVE-2022-21985; CVE-2020-17133; CVE-2023-36905.	1.Блокировать подозрительные HTTP/SMB по сигнатурам RCE; 2.Ограничить запуск файлов из системных директорий; 3.Проверить логи на появление несанкционированных файлов в системных папках.	1.Отключить неиспользуемые службы и ограничить доступ в системные папки; 2. Провести очистку нестандартных OpenSSL библиотек; 3.Установить обновления закрывающие уязвимости CVE-2022-21985; CVE-2020-17133; CVE-2023-36905.
Предотвращение обнаружения	Преступник скрывает свои действия в системе с помощью (T1562.2) через эксплуатацию CVE-2025-21214 CVE-2024-21183.	1. Анализ поведения процессов на предмет изменения DLL. 2. Проверить и очистить записи в HKLM\SYSTEM \CurrentControlSet\Services.	1.ВнедритьВнедреить контроль целостности системных файлов; 2. Запрет на запуск неизвестных скриптов через HIPS; 3.ПересмотретьПеремотреть парольную политику

Продолжение таблицы Б1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Получение учетных данных	Нарушение конфиденциальности для учетных данных, небезопасно хранящихся (T1552) на устройствах, с помощью CVE-2018-8444, CVE-2024-36036, CVE-2022-38026, CVE-2021-40454.	1. Анализ поведения процессов на предмет изменения DLL. 2. Пересмотреть политику доступа к конфигурационным файлам. 3.Настроить блокировку хостов, которые собирают информацию с помощью разведывательных запросов.	1.Внедрить парольную политику с необходимостью смены пароля в указанный промежуток времени для предотвращения возможного раскрытия учетных; 2.Логирование действий пользователей, которые подключаются к хранилищам; 3.Настроить отслеживание и предотвращение запуска, несанкционированных утилит сбора системной информации.
Обнаружение	Сбор информации о сети (T1016) учетных данных (T1087) и системной информации (T1082) через уязвимости.	1. Настроить WAF фильтрацию для ограничения доступа извне; 2. Остановить маскирующиеся процессы, собирающие информацию; 3. Блокировать порт при активном использовании RDP сессии хостом.	1.Оперативно установить обновления, закрывающие; соответствующие уязвимости. 2. Обеспечить разграничение сети; 3. Проверить вероятность заражения узла, каким-либо сторонним скриптом.
Перемещение внутри периметра	Перемещение в сети с помощью (T1021.007) с эксплуатации CVE-2023-32037, CVE-2022-30134, CVE-2024-43609.	1.Блокировать источники подозрительных сессий; 2. Анализ логов с сервера для удаленного доступа к сети; 3.Включить обязательную проверку подписи SMB на удаленных серверах.	1. Установить патчи на закрытие уязвимостей CVE-2023-32037, CVE-2022-30134, CVE-2024-43609; 2.Пересмотреть политику доступа сервисных аккаунтов удаленного доступа; 3.Развернуть ловушки, имитирующие сетевые сервера с оповещениями для попыток подключении.

Таблица – Б2 Организационно-правовые регламенты вектора атаки CAPEC-301

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Разведка	На этапе Разведки логи межсетевого экрана фиксируют большой всплеск TCP подключений (T1595), с возможным эксплуатированием уязвимостей CVE-2019-0688, CVE-2021-28442	1. При появлении аномальной активности необходимо блокировать все подозрительные соединения с помощью межсетевого экрана и ограничить скорость новых соединений; iptables -A INPUT -p tcp --syn -m connlimit --connlimit-above 10 -j DROP 2. Записывать дамп поступающего трафика злоумышленника tcpdump -i eth0 tcp and '(tcp[tcpflags] & tcp-syn != 0)' -w tcp_scan.pcap 3.Заблокировать хосты генерирующие аномальные TCP пакеты	1.Установить официальные патчи, с целью закрыть 2019-0688, CVE-2021-28442; 2.Реализовать сегментацию сети с помощью настройки VLAN для отделения наиболее важных сетевых сервисов. 3. Использовать средства обнаружения вторжений на детекцию сканирования портов: snort -A fast -c /etc/snort/snort.conf
	Аномально большое количество полных TCP соединений не завершающихся передачей данных, что может свидетельствовать о реализации (T1590.004) с помощью 2021-45486, CVE-2021-39203.	1. С помощью средств обнаружения вторжений ограничить число одновременно полных сетевых подключений iptables -I INPUT -p tcp --tcp-flags ALL FIN, URG,PSH -j DROP. 2.Проанализировать дамп tcpdump -n -i eth0 tcp -w scan.pcap 3. С помощью межсетевого экрана ограничить входящие соединения.	1.Пропатчить сетевые службы с целью устранения уязвимостей CVE-2021-45486, CVE-2021-39203 2. Ужесточить межсетевое взаимодействие устройств на пограничных узлах. 3. Настроить IDS/IPS на блокировку нестандартных пакетов: suricata-update && systemctl restart suricata.
Первоначальный доступ	Журналы WAF фиксируют аномальные сетевые пакеты с признаками попытки эксплуатации уязвимостей сетевых служб,	1. Установить мониторинг за созданием нестандартных бинарей в %TEMP% и C:\Windows\Temp.3. 2.Изолировать зараженный хост от остальной сети	1. Обновить все каналы передачи файлов (FTP, SMB, HTTP-upload) до версий с исправлениями CVE-2021-39203,

	что свидетельствует о реализации T1205 с помощью CVE-2021-39203, CVE-2024-11376, CVE-2023-39326.	ip link set eth0 down 3. Проверить логи RCE-попыток grep "RCE attempt" /var/log/syslog .	CVE-2024-11376, CVE-2023-39326 2. Провести ротацию и отозвать скомпрометированные сервисные учетные записи. 3.Отключить неиспользуемые сервисы передачи (в т.ч. встроенный FTP в IIS).
Предотвращение обнаружения	WAF сигнализируетсигнализирует об попытках отключения/маскировки средств контроля (T1562) с эксплуатацией CVE-2024-21243; CVE-2022-11898.	1.С помощью системных журналов зафиксировать состояние системы. 2. Остановить подозрительные процессы. 3. С помощью межсетевого экранирования изолировать зараженный хост.	1. Восстановить логи и конфигурацию агентов из защищённых бэкапов. 2. Удалить все обнаруженные маскировочные утилиты и драйверы. 3. Установить патчи закрывающие CVE-2024-21243; CVE-2022-11898.
Обнаружение	IDS фиксирует подозрительное обращение к ресурсам находящимся внутри защищаемой сети (T1046) с применением CVE-2023-35952.	1. С помощью межсетевого экрана блокировать подозрительные попытки просканировать сеть 2.Установить оповещения на применение утилит сканеров в системе.	1. Перезапустить сетевые службы и сбросить ARP таблицы на ключевых устройствах 2. Патчинг уязвимости CVE-2023-35952. 3. Ужесточить политику в отношении TCP-пингов в системе.
Перемещение внутри периметра	Логи SSH/RDP фиксируют успешные подключения и попытки получения привилегий с использованием техники удалённого сервиса, что свидетельствует о (T1563).	1. Ограничить последние подключения SSH/RDP 2.Заблокировать запросы через межсетевой экран New-NetFirewallRule -Name "BlockWMI" -Program "C:\Windows\System32 \wbem\wmiprvse.exe"	1. Внедрить многофакторную аутентификацию для сервиса SSH 2. Установить обновления для закрытия уязвимостей CVE-2023-6332; CVE-2021-4160.

Продолжение таблицы Б2

Этапность реализации кибератак,	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов

рекомендованная MITRE ATT&CK			
Перемещение внутри периметра	IDS фиксирует использование удаленных уязвимостей (CVE-2022-32221) для получения доступа к соседним хостам (T1210).	1. Заблокировать сетевые порты 3389 и 1099. 2. Блокировать подозрительные HTTP-запросы с помощью брандмауэра.	1. Внедрить в сеть корректно настроенную DMZ. 2. Пересмотреть уровневую политику для пользователей 3. Установить патчи для CVE-2022-32221.
Деструктивное воздействие	Системные логи фиксируют массовое нарушение доступности файлов, что свидетельствует о применении T1565 с уязвимостями CVE-2025-21242, CVE-2022-46698, CVE-2025-7848.	1. Остановить вредоносныйвредоностный процесс pkill -f encryptor. 2. Пересмотреть политики доступа к файловой системе. 3. Включить мониторинг командной строки uditctl -a always,exit -F arch=b64 -S execve -k cmdline_monitoring.	1. Установить патчи для закрытия уязвимостей CVE-2025-21242, CVE-2022-46698, CVE-2025-7848. 2.Организовать контроль целостности системных файлов для предотвращения будущего нарушения доступности. 3.Организовать резервное копирование данных критически важных системных файлов.

Таблица – Б3 Организационно-правовые регламенты вектора атаки CAPEC-302

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Разведка	Система обнаружения вторжений фиксирует поток TCP-пакетов с подозрительными флагами T1595 с помощью CVE-2018-15919, CVE-2019-0848, CVE-2019-1108.	1. Заблокировать FIN-сканы на уровне iptables: iptables -A INPUT -p tcp --tcp-flags FIN FIN -j DROP 2. Добавить TCP-FIN скан сигнатуры для IDS и настроить алерты для их аномальных всплесков	1. Пропатчить ядро/стек TCP/IP CVE-2018-15919, CVE-2019-0848, CVE-2019-1108.

Продолжение таблицы Б3

Этапность реализации кибератак,	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов

рекомендованная MITRE ATT&CK			
		3. Заблокировать источники аномальных TCP-пакетов.	2. Использовать туннелирование для отделения критических сервисов. 3. Настроить сетевой экран на блокировку доступности TCP порта 502 из незащищенной зоны.
Первоначальный доступ	Логи сигнализируют о множественных неудачных попытокпопыткок аутентификации (T1133) с использованием CVE-2019-0977; CVE-2019-0608; CVE-2020-3182.	1. Завершить активные сессии злоумышленника pkill -u attacker_user 2. Отклонить подсеть на уровне firewalld: firewall-cmd --permanent --add-rich-rule='rule family=ipv4 source address=<subnet> reject'firewall-cmd –reload 3. Включить аудит сетевых попыток аутентификации: auditctl -a exit,always -F arch=b64 -S connect -k remote_access	1. Сбросить пароли и перевыпустить сертификаты. 2. Отключить или изолировать неиспользуемые сервисы (RPC, RPC-over-HTTP и пр.). 3. Внедрить многофакторную аутентификацию.
Предотвращение обнаружения	Маскировка эксплойтов под легитимные файлы сигнализирует о маскировке процессов и изменении логов T1070 (CVE-2019-0977, CVE-2019-6806, CVE-2022-3182).	1. Включить аутит: auditctl -e 1 2. Обновить IDS, дополнив новые сигнатуры. 3. Реализовать контроль целостности логов.	1. Ввести контроль полноты файлов для системных папок. 2. Реализовать перенаправление логов на удаленный хост сети 3. Обновить программное обеспечение для CVE-2019-0977, CVE-2019-6806, CVE-2022-318.
Обнаружение	IDS сигнализирует об активном сборе системной и сетевой информации через уязвимости (T1046) и (T1046) с помощью ???	1. добавить сигнатуры на аномальное чтение трафика. 2. Ограничить возможность запуска неавторизованных утилит.	1.Установить обновления CVE-2020-2889, CVE-2021-33783. 2. Блокировать порт при активном использовании RDP сессии хостом.

Продолжение таблицы Б3

Этапность реализации кибератак,	В соответствии с MITRE этапностью регистрируемые	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов

рекомендованная MITRE ATT&CK	инциденты		
Деструктивное воздействие	Системные логи фиксируют массовое нарушение доступности файлов, что свидетельствует о применении T1565 с применением уязвимостей CVE-2025-21242, CVE-2022-46698.	1. Остановить вредоносный процесс pkill -f encryptor. 2. Включить мониторинг командной строки. uditctl -a always,exit -F arch=b64 -S execve -k cmdline_monitoring 3. Пересмотреть политики доступа к файловой системе.	1. Установить патчи для закрытия уязвимостей CVE-2025-21242, CVE-2022-46698. 2.Организовать контроль целостности системных файлов для предотвращения будущего нарушения доступности. 3.Организовать резервное копирование данных критически важных системных файлов.
Деструктивное воздействие	Точечные отказы в системе сигнализируют от (T1499) с помощью CVE-2018-7848.	1.С помощью межсетевого экрана ограничить подозрительный трафик iptables -A INPUT -p tcp --syn -m limit --limit 1/s -j ACCEPT. 2.Провести анализ журналов сетевого трафика. 3.Перезапустить отказавшие сервисы или хосты.	1.Организовать второстепенные узлы для распределения нагрузки на устройство. 2.Установить внешний DDos-фильтр.

Таблица – Б4 Организационно-правовые регламенты вектора атаки CAPEC-304

Этапность реализации	В соответствии с MITRE	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий

кибератак, рекомендованная MITRE ATT&CK	этапностью регистрируемые инциденты		инцидентов
Разведка	Система обнаружения вторжений фиксирует поток TCP-пакетов с отсутствующими флагами (T1595) с помощью CVE-2022-1012, CVE-2023-45236, CVE-2018-15473.	1. Анализ сетевых пакетов на присутствие с нулевым количеством TCP-флагов. 2.Установить порог возможных пакетов входящих в сеть. 3.Включить сигнатуры безфлаговых TCP-пакетов для автоматической блокировки IDS-ом.	1.Установить патчи для CVE-2022-1012, CVE-2023-45236, CVE-2018-15473. 2. Сегментировать сеть с помощью VLAN. 3. Ужесточить правила для входящего трафика на пограничных устройствах.
Первоначальный доступ	Эксплуатация уязвимостей (CVE-2019-0977, CVE-2019-0608, CVE-2020-3182) для реализации техники T1133.	1. Отключить доступ к критичным сервисы и переключить сами модули в режим расследования. 2. Отключить форму восстановления пароля для дальнейшего обслуживания. 3. Сохранить логи для последующего анализа.	1. Внедрить многофакторную аутентификацию. 2. Установить патчи для CVE-2019-0977, CVE-2019-0608, CVE-2020-3182 и т. д. 3.Принудительно отозвать все пароли.
Перемещение внутри периметра	IDS фиксирует использование удаленных уязвимостей (CVE-2022-32221) для получения доступа к соседним хостам (T1210).	1. Заблокировать сетевые порты 3389. 2. Блокировать подозрительные HTTP-запросы с помощью брандмауэра 3. Блокировать хосты создающие подозрительных сессий.;	1. Внедрить в сеть корректно настроенное тунелирование. 2. Пересмотреть уровневую политику для пользователей. 3. Установить патчи для CVE-2022-32221.
Обнаружение	Брандмауэр фиксирует сбор информации о сети, учетных и и что свидетельствует о реализации (T1016) через уязвимости CVE-2018-15919, CVE-2024-21243 CVE-2019-0408 CVE-2019-1108.	1. Настроить WAF фильтрацию для ограничения доступа извне. 2. Остановить маскирующиеся процессы, собирающие информацию.	1.Оперативно установить обновления, закрывающие; соответствующие уязвимости. 2. Обеспечить разграничение сети.;

Продолжение таблицы Б4

Этапность реализации кибератак,	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов

рекомендованная MITRE ATT&CK			
Сбор данных	Система обнаружения вторжений фиксирует подозрительный исходящий трафик из (T1048), с использованием: CVE-2022-11898.	1. Блокировать неизвестные исходящие порты для передачи данных. 2. Включить SMB-шифрование Set-SmbShare -Name "Finance" -EncryptData $true 3. Заблокировать исходящие порты 445 и 139. New-NetFirewallRule -DisplayName "Block CIFS Exfil" -Direction Outbound -Protocol TCP -RemotePort 445,139 -Action Block.	1. Обеспечить непрерывный мониторинг исходящего из системы трафика на несанкционированные сетевые порты. 2. Мониторинг процессов, запускающие HTTP запросы, которые имеет подозрительную нагрузку.
Сбор данных	В логах фиксируется, аномальные кодировки трафика в обычном канале связи (T1041) с помощью CVE-2021-43236, CVE-2021-34500.	1. Включить DLP-фильтрацию для трафика. 2. Заблокировать удаленный вызов командной строки из оболочки администратора. 3. Настроить шифрование всех внешних каналов.	1. Включить глубокое рассмотрение пакетов на DNS тунели. 2. Настройка мониторинга подозрительных последовательностей символов в ACL. 3.Сформировать белый список доменных имен.